

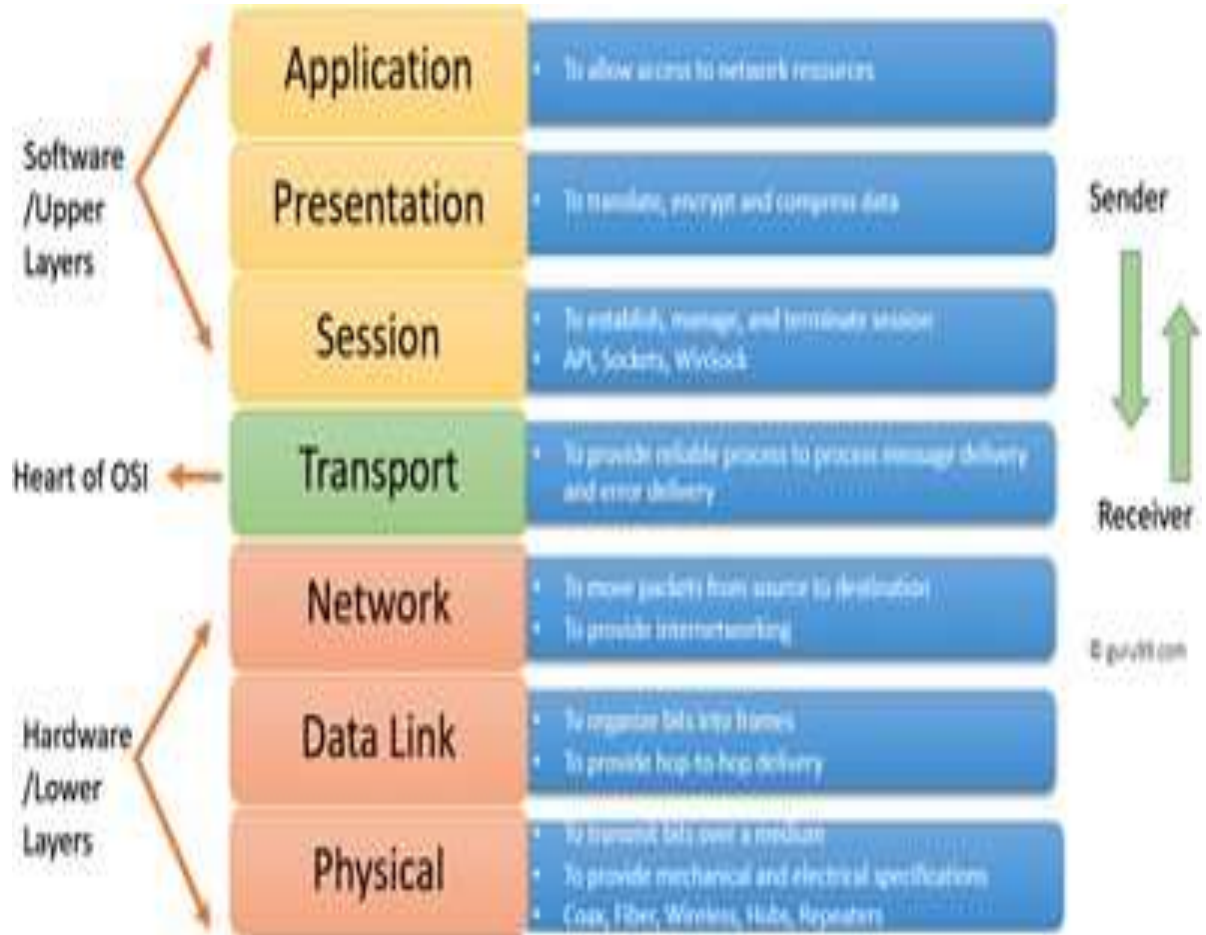
Unit-4

Security Requirements

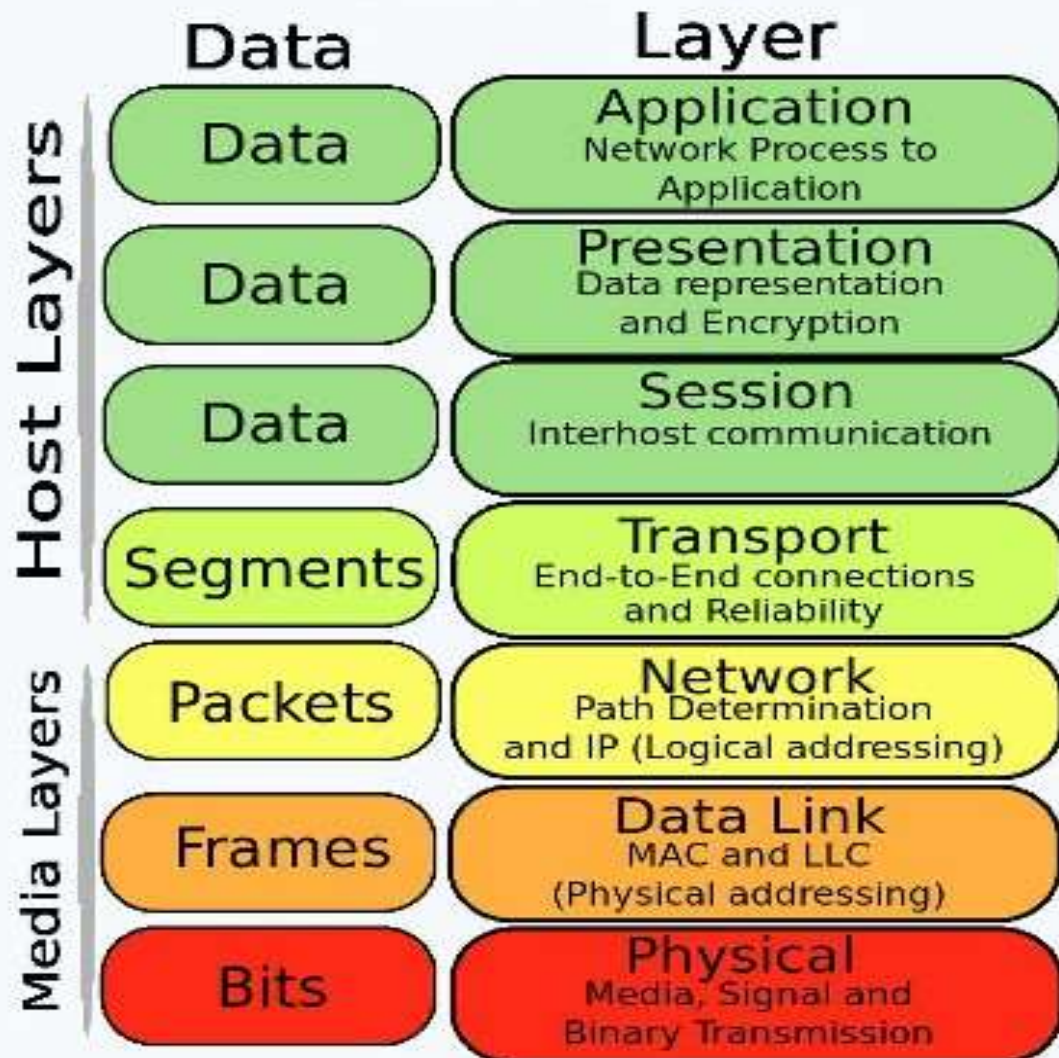
Basics about CN

OSI reference model

Application
Presentation
Session
Transport
Network
Datalink
Physical



OSI Model



Application Layer -This is where the user application sits that needs to transfer data between or among hosts. For example – HTTP, file transfer application (FTP) and electronic mail etc.

Presentation Layer- This layer helps to understand data representation in one form on a host to other host in their native representation.

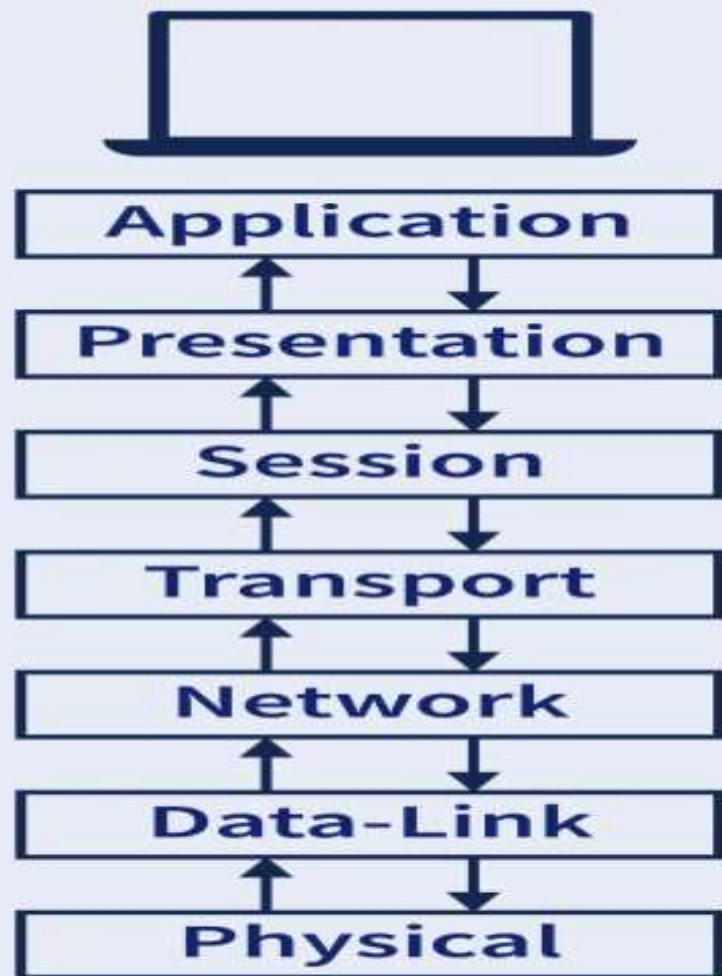
Session Layer- This layer provides session management capabilities between hosts. This layer can assist in synchronization, dialog control and critical operation management (e.g., an online bank transaction).

Transport Layer- This layer provides end to end data delivery among hosts. This layer takes data from the above layer and breaks it into smaller units called Segments and then gives it to the Network layer for transmission.

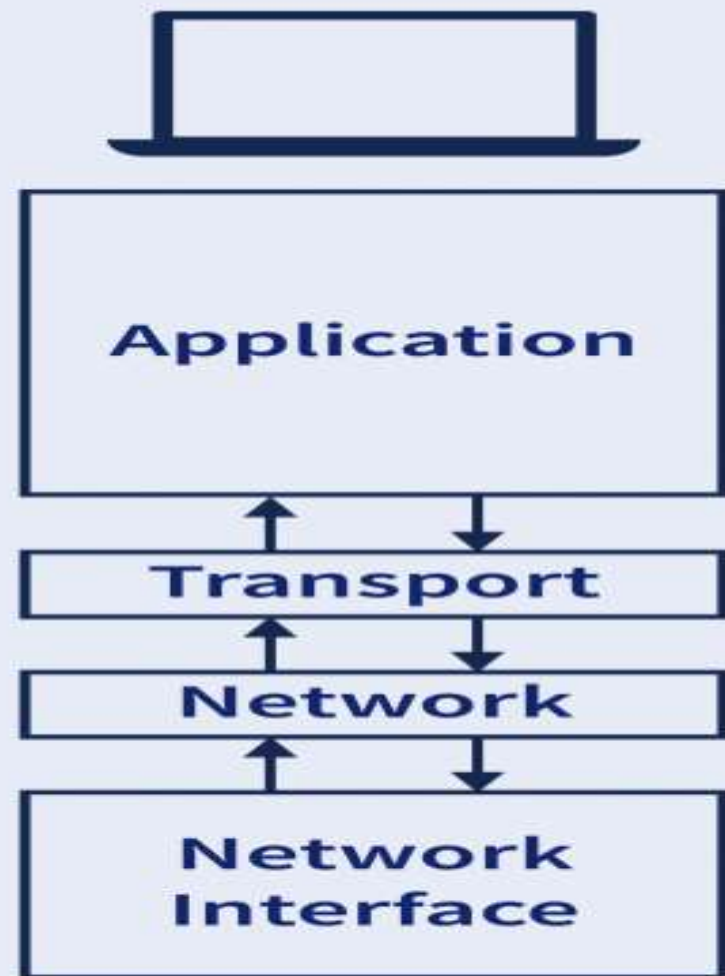
Network Layer- helps to uniquely identify hosts beyond and defines the path which the packets will follow or be routed to reach the destination.

Data Link Layer- takes the raw transmission data (signal, pulses etc.) from the Physical Layer and makes Data Frames, and sends that to the upper layer and vice versa. This layer also checks any transmission errors and sorts it out accordingly.

Physical Layer –deals with hardware technology and actual communication mechanism such as signaling, voltage, cable type and length, etc.



OSI Model



TCP/IP Model

TCP/IP Reference Model

Application Layer

- Responsible for the user interfaces and application services.
- Responsible for formatting messages for transport layer.

Transport Layer or Host-to-Host Layer

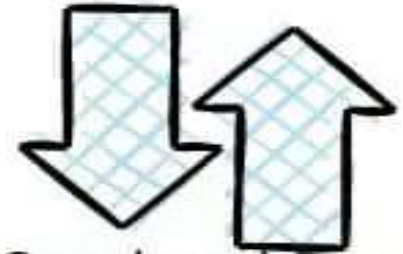
- Ensures data is delivered reliably and in order.

Internet Layer

- Provides IP address and Routing data between devices.

Network Access Layer or Link Layer

- Transmits raw data bits over a physical medium.
- Provide MAC addressing and LLC.



Send and Receive

Afroz Ahmad

Outcomes for Unit III

Unit IV	Security Requirements	(08 Hours)
IP Security: Introduction, Architecture, IPV6, IPv4, IPSec protocols, and Operations, AH Protocol, ESP Protocol, ISAKMP Protocol, VPN. WEB Security: Introduction, Secure Socket Layer (SSL), SSL Session and Connection, SSL Record Protocol, Change Cipher Spec Protocol, Alert Protocol, Handshake Protocol. Electronic Mail Security: Introduction, Pretty Good Privacy, MIME, S/MIME, Comparison. Secure Electronic Transaction (SET).		

Security requirement

- A requirement **collect from legal authority** such as information system or an organization that is **derived from applicable laws, executive orders, directives, regulations, policies, standards, procedures, or mission/business**
- **needs** to ensure the confidentiality, integrity, and availability of information that is being processed.

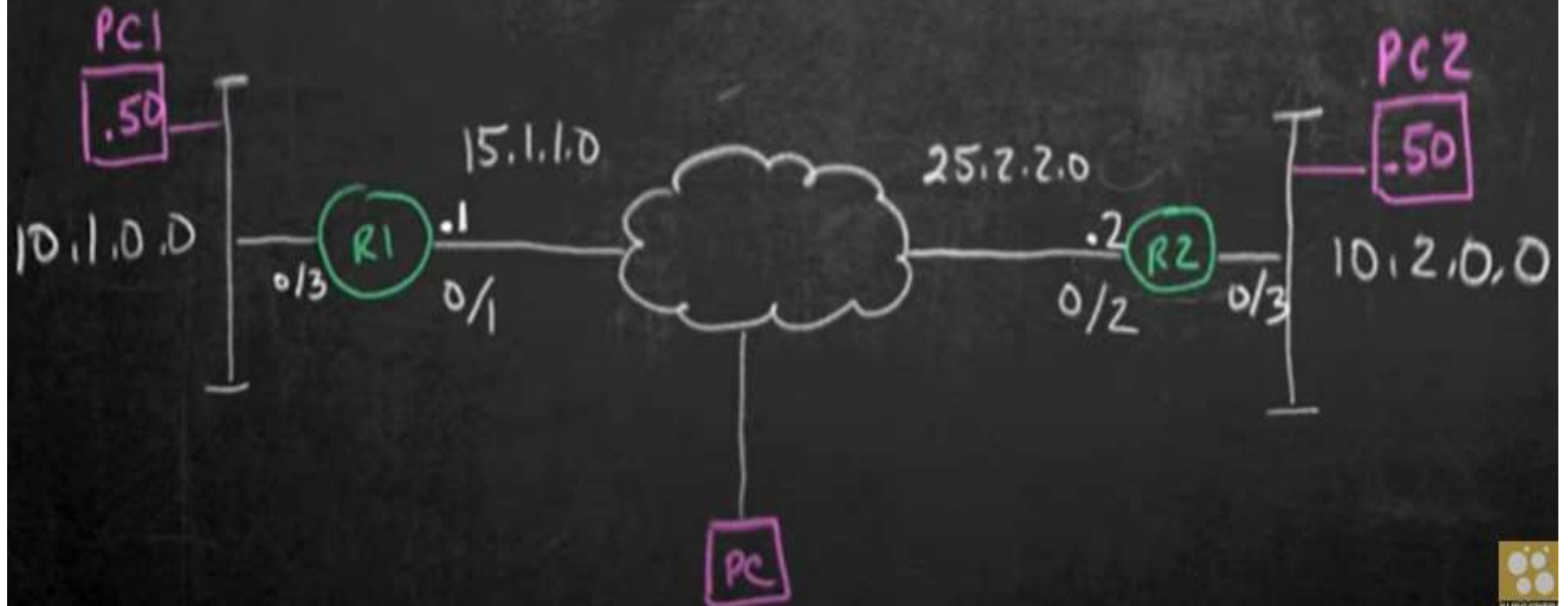
IP Security : Introduction

- IP Sec (Internet Protocol Security) is an **Internet standard suite of protocols** between two communication points across the IP network. that provide data C,I,A.
- IPsec is a **group of protocols for securing connections between devices. IPsec helps keep data sent over public networks secure.**
- It also defines the **encrypted, decrypted, and authenticated packets.**
- The protocols needed for **secure key exchange and key management** are defined in it.
- When you invoke IPsec, IPsec applies the security mechanisms to IP datagrams that **you have enabled in the IPsec global policy file.**
- **Applications can invoke IPsec** to apply security mechanisms to IP datagrams on a per-socket level.

IPsec

PRIVACY
Data Integrity

Encrypt
HASH

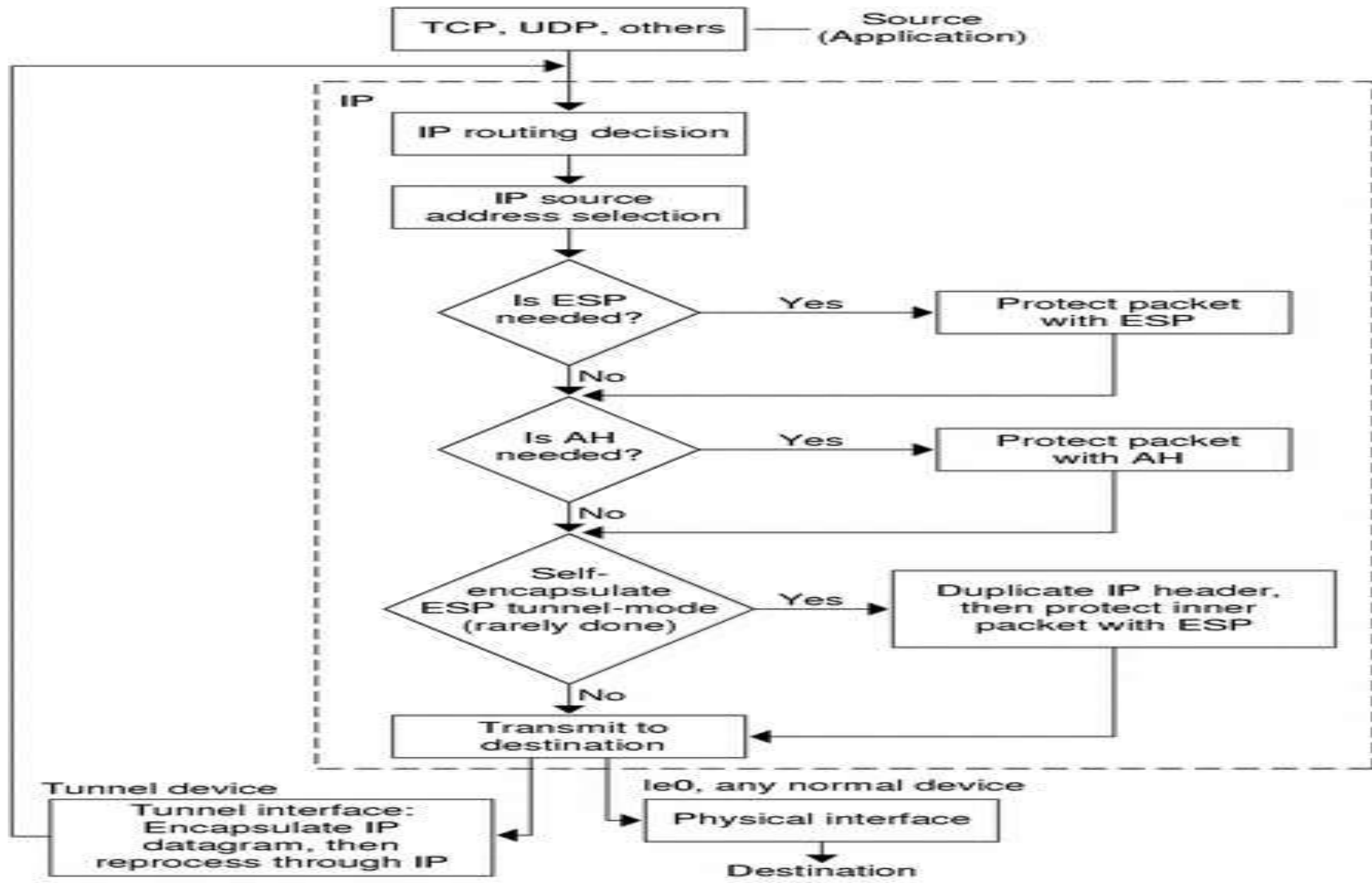


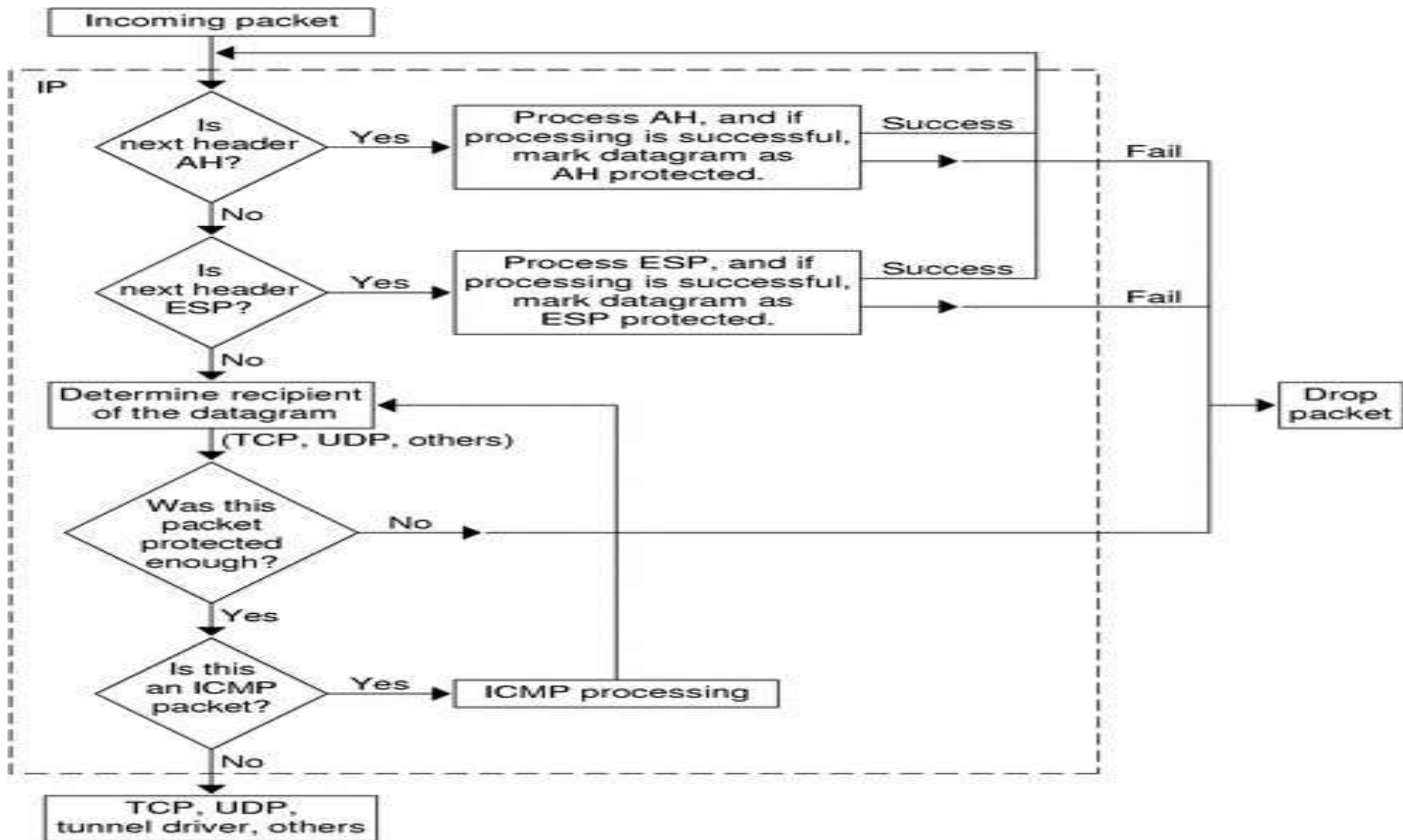
→ IPsec PRIVACY
Data Integrity ENCRYPT
HASH



First diagram-Outbound process

Second diagram-Inbound process





Uses of IP Security

- To encrypt application layer data.
- To provide security for routers sending routing data across the public internet.
- To provide authentication without encryption, like to authenticate that the data

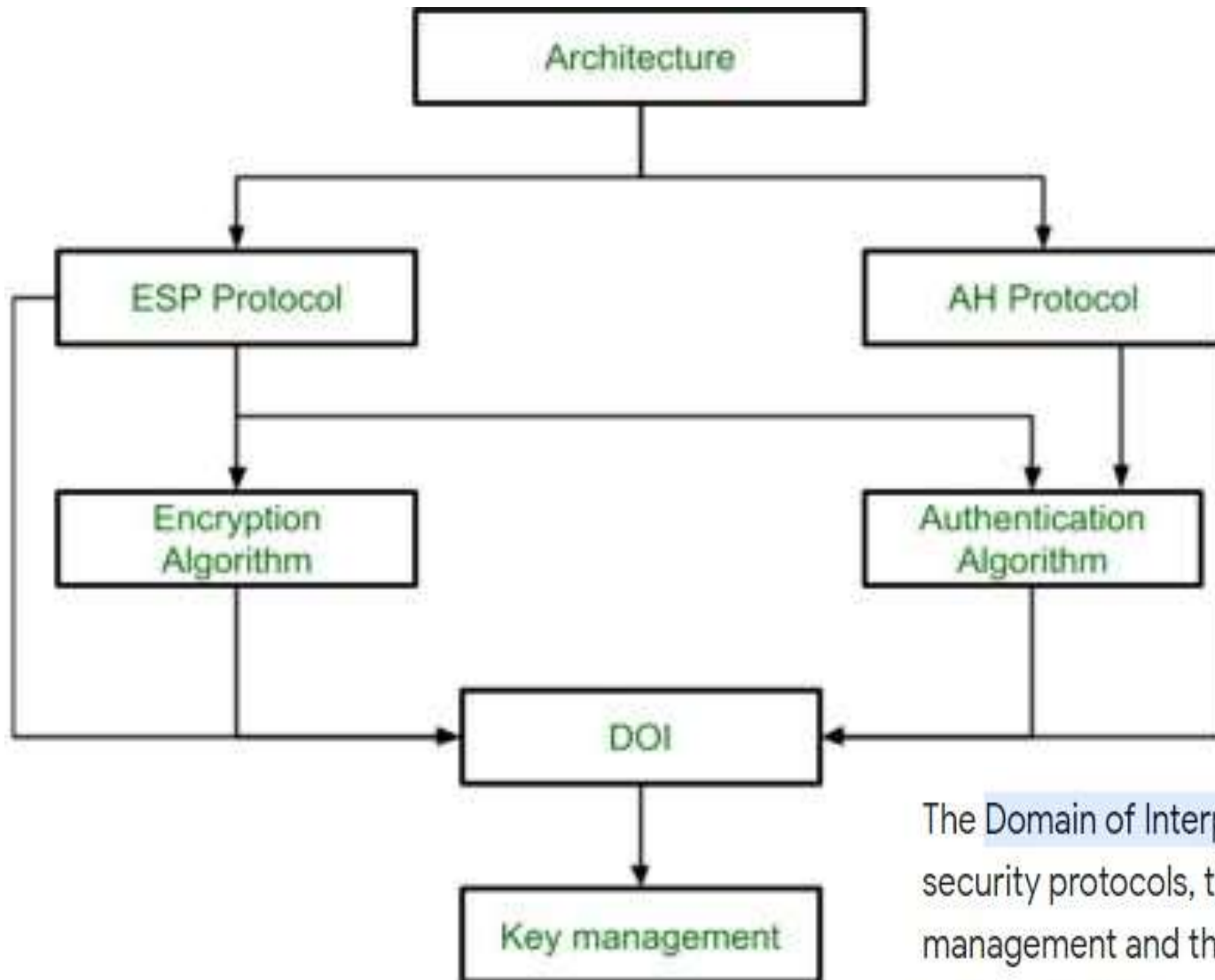
Components of IP Security

- **ESP(Encapsulating Security Payload)**-It provides data integrity, encryption, authentication, and anti- replay. It also provides authentication for payload.
- **AH(Authentication Header)**-It also provides data integrity, authentication, and anti-replay but does not provide encryption. It does not protect data confidentiality.
- **IKE(Internet Key Exchange)**-It is a network security protocol designed to dynamically exchange encryption keys and find a way over Security Association (SA) between 2 devices.
- **Encryption Algorithm:** algorithm is the
- document that describes various encryption algorithms used for Encapsulation Security Payload.

- 5. Authentication Algorithm:** The authentication Algorithm contains the set of documents that describe the authentication algorithm used for AH and for the authentication option of ESP.
- 6. DOI (Domain of Interpretation):** DOI is the identifier that supports both AH and ESP protocols. It contains values needed for documentation related to each other.
- 7. Key Management:** Key Management contains the document that describes how the keys are exchanged between sender and receiver.

IP Security Architecture

- [IPSec \(IP Security\) architecture](#) uses two protocols to secure the traffic or data flow.
- These protocols are ESP (Encapsulation Security Payload) and AH (Authentication Header).
- IPSec Architecture includes protocols, algorithms, and Key Management.
- All these components are very important in order to provide the three main services:
 - Confidentiality
 - Authenticity
 - Integrity



The **Domain of Interpretation** contains the information about the security protocols, the algorithms and the procedures for the key management and thus important parameters for an IPsec communication. 24-Oct-2007

IPSec Modes of Operation

Transport Mode	Tunnel Mode
IPSec in the transport mode does not protect the IP header; it only protects the information coming from the transport layer.	IPSec in the tunnel mode protects the original IP header.



Transport Mode

- IPsec header is inserted into the IP packet
- No new packet is created
- Works well in networks where increasing a packet's size could cause an issue
- Frequently used for remote-access VPNs

Tunnel Mode

- Entire IP packet is encrypted and becomes the data component of a **new (and larger) IP packet**.
- Frequently used in an IPsec site-to-site VPN



Without IPsec



Transport Mode
IPsec



Tunnel Mode
IPsec

ESP

It responsible for the [CIA triad](#) of security (Confidentiality, Integrity, Availability).

Securing all payload/ packets/ content in IPv4 and IPv6 is the responsibility of ESP.

Working of ESP:

1. Encapsulating **Security Payload**.
2. It performs the **functioning of encryption in headers** of Internet Protocol or in general say, it resides and performs functions in IP Header.
3. The **insertion of ESP** is between Internet Protocol and other protocols such as [UDP/](#)
[TCP/ ICMP](#).

Modes in ESP:

Tunnel mode:

1. Mandatory in **Gateway**, tunnel mode holds greatest importance.
2. Here, **a new IP Header is created** which is used as the outer IP Header followed by ESP.

Transport mode:

1. Here, IP Header is not protected.
2. Less processing is seen in this mode.

Original Packet
Protocol (1 – ICMP, 6 – TCP, 17 – UDP)

Original IP Header

Data

IPsec Transport Mode
Protocol (50 – ESP)

Original IP Header

ESP Header

Data

ESP Trailer

ESP Auth

ESP Encrypted

ESP Authenticated

IPsec Tunnel Mode
Protocol (50 – ESP)

Original IP Header

ESP Header

Original IP Header

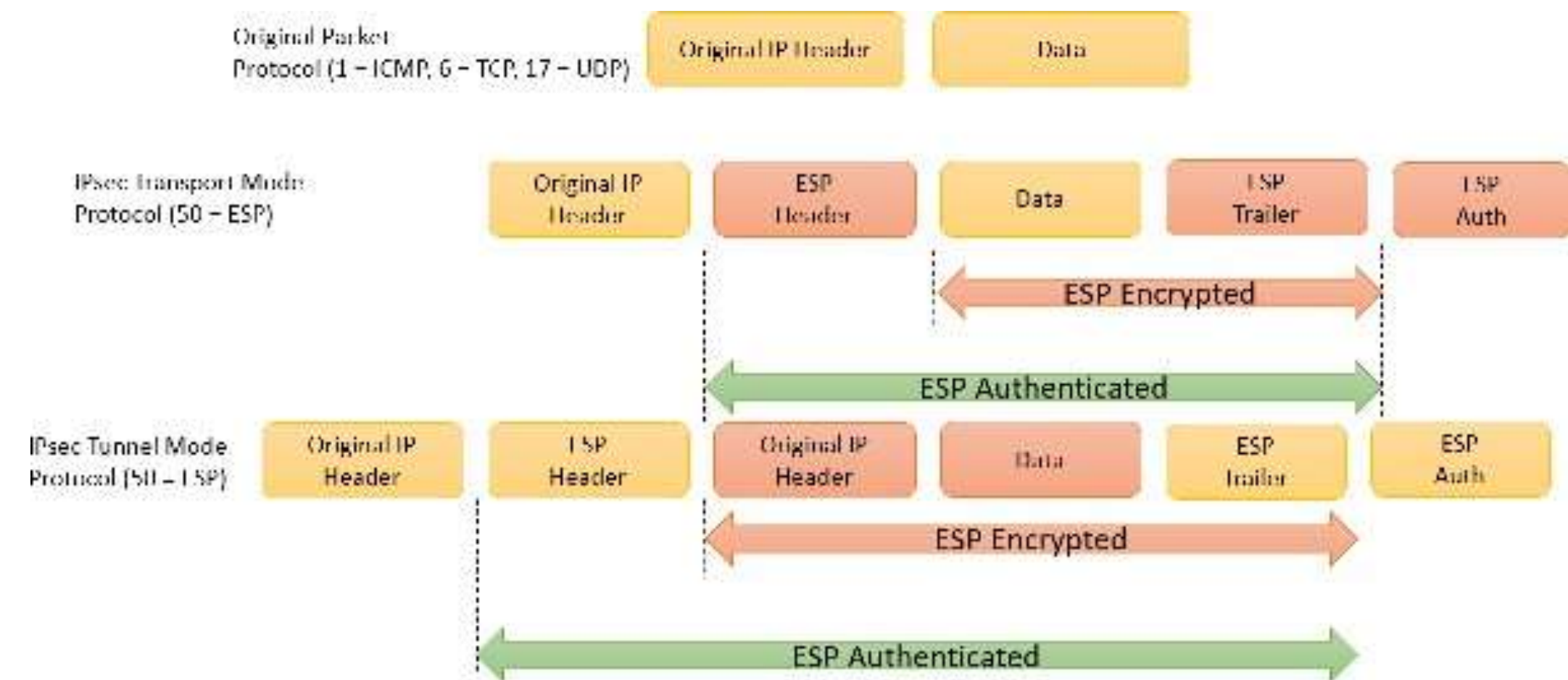
Data

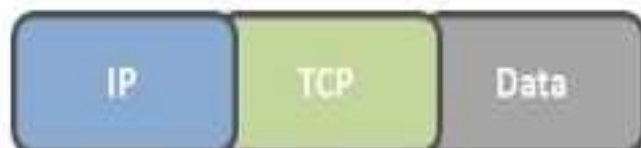
ESP Trailer

ESP Auth

ESP Encrypted

ESP Authenticated





IP Packet



AH Header (Transport)



AH Header (Tunnel)



ESP Header (Transport)



ESP Header (Tunnel)

Advantages:ESP

1. Encrypting data to provide security
2. Maintaining a secure gateway for data/ message transmission
3. Properly authenticating the origin of data
4. Providing needed data integrity
5. Maintaining data confidentiality
6. Helping with anti-replay service using authentication header

Disadvantages:

1. restriction on the **encryption method** to be used
2. For global use and implementation, weaker encryptions are mandatory to use

Security Parameter		
Sequence Number		
Pay load Data		
Padding		
<table border="1"><tr><td>Padding Length</td><td>Next Header</td></tr></table>	Padding Length	Next Header
Padding Length	Next Header	
Authentication Data		

1. Security Parameter :

- Security parameters are assigned a size of 32 bits and for security links and associations

2. Sequence Number:

- The sequence number is 32 bits in size and works as an incremental counter.

3. Payload Data:

- Payload data don't have fixed size and are variable in size to use
- It refers to the data/ content that is provided security by the method of encryption

4. Padding:

- Padding has an assigned size of 0-255 bytes assigned to it.
- Padding is done to ensure that the payload data fits into the cipher block correctly,

5. Pad Length:

- Pad Length is assigned the size of 8 bits to
- use It is a measure of pad bytes that are

6. Next Header:

- The next header is associated with a size of 8 bits to use
- It is responsible for determining the data type of payload by studying the first header of the payload

7. Authentication Data:

- The size associated with authentication data is variable and never fixed
- Authentication data is an optional field that is applicable only when SA is selected. It serves the purpose of providing integrity

AH Protocol: AH (Authentication Header) Protocol provides both Authentication and Integrity service. Authentication Header is implemented in one way only: Authentication along with Integrity.

Next Header	Payload Length	Reserved
Security Parameter Index		
Sequence Number		
Authentication Data (Integrity Checksum)		

Network Layer

- The network layer is responsible for carrying data from one host to another.
- It provides means to allocate logical addresses to hosts, and identify them uniquely using the same.
- Network layer takes data units from Transport Layer and cuts them in to smaller unit called Data Packet.
- Network layer defines the data path, the packets should follow to reach the destination.
- Routers work on this layer and provides mechanism to route data to its destination.

IPv4 - TCP/IP Model

- A majority of the internet uses a protocol suite called the Internet Protocol Suite also known as the TCP/IP protocol suite.
- This suite is a combination of protocols which encompasses a number of different protocols for different purpose and need. Because the two major protocols in this suites are TCP (Transmission Control Protocol) and IP (Internet Protocol), this is commonly termed as TCP/IP Protocol suite.
- This protocol suite has its own reference model which it follows over the internet. In contrast with the OSI model, this model of protocols contains less layers.

Internet Protocol Version 4 (IPv4)

- Internet Protocol is one of the major protocols in the TCP/IP protocols suite. This protocol works at the network layer of the OSI model and at the Internet layer of the TCP/IP model. Thus this protocol has the responsibility of identifying hosts based upon their logical addresses and to route data among them over the underlying network.
- IP provides a mechanism to uniquely identify hosts by an IP addressing scheme. IP uses best effort delivery, i.e. it does not guarantee that packets would be delivered to the destined host, but it will do its best to reach the destination. Internet Protocol version 4 uses 32-bit logical address.

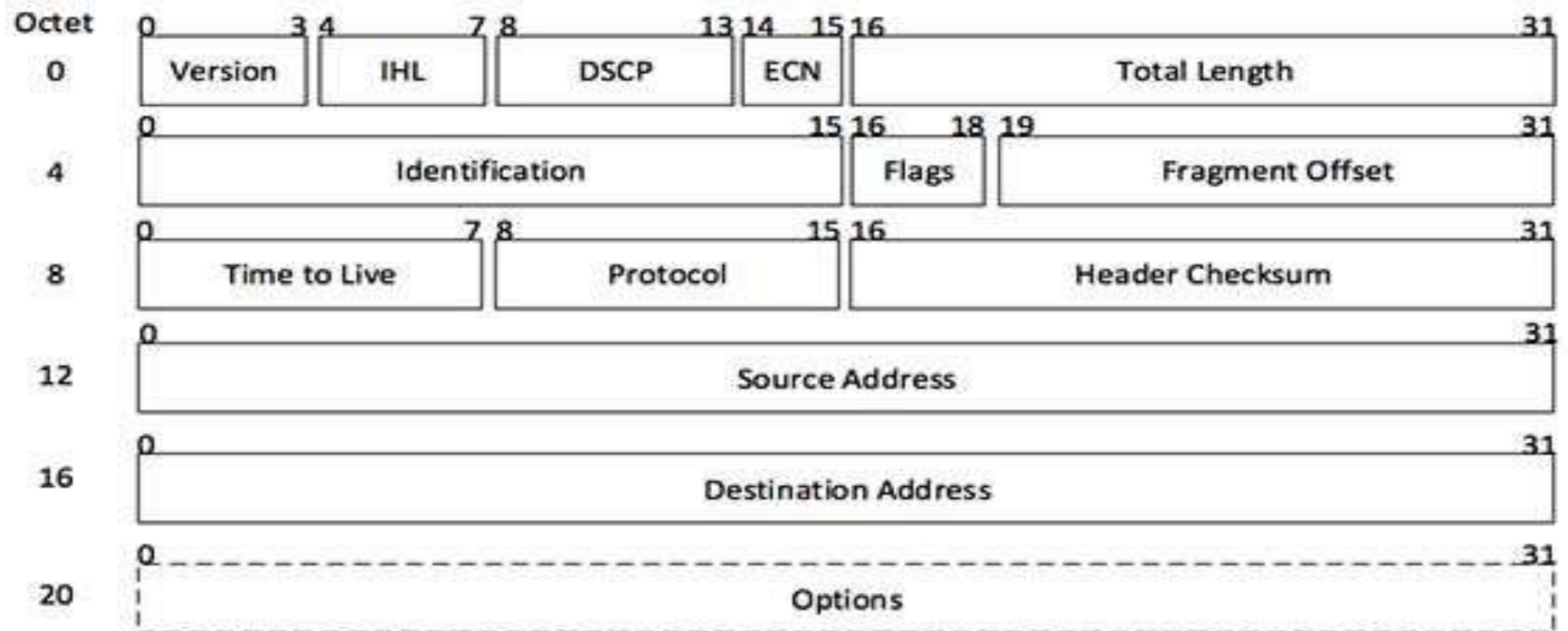
IPv4 - Packet Structure

- Internet Protocol being a layer-3 protocol (OSI) takes data Segments from layer-4 (Transport) and divides it into packets. IP packet encapsulates data unit received from above layer and add to its own header information.



(IP Encapsulation)

- The encapsulated data is referred to as IP Payload. IP header contains all the necessary information to deliver the packet at the other end.



[Image: IP Header]

- **Version** - Version no. of Internet Protocol used (e.g. IPv4).
- **IHL** - Internet Header Length; Length of entire IP header.
- **DSCP** - Differentiated Services Code Point; this is Type of Service.
- **ECN** - Explicit Congestion Notification; It carries information about the congestion seen in the route.
- **Total Length** - Length of entire IP Packet (including IP header and IP Payload).
- **Identification** - If IP packet is fragmented during the transmission, all the fragments contain same identification number. to identify original IP packet they belong to.
- **Flags** - if IP Packet is too large to handle, 'flags' tells if they can be fragmented or not. In this 3-bit flag, the MSB is always set to '0'.
- **Fragment Offset** - This offset tells the exact position of the fragment in the original IP Packet.
- **Time to Live** - To avoid looping in the network, every packet is sent with some TTL value set, which tells the network how many routers (hops) this packet can cross. At each hop, its value is decremented by one and when the value reaches zero, the packet is discarded.

Protocol:Tells the Network layer at the destination host, to which Protocol this packet belongs to, i.e. the next level Protocol. For example protocol number of ICMP is 1, TCP is 6 and UDP is 17.

Header Checksum- This field is used to keep checksum value of entire header which is then used to check if the packet is received error-free.

Source Address- 32-bit address of the Sender (or source) of the packet.

Destination Address:32-bit address of the Receiver (or destination) of the packet.

Options:This is optional field, which is used if the value of IHL is greater than 5. These options may contain values for options such as Security, Record Route, Time Stamp, etc.

IPv6

- IPv6 or Internet Protocol Version 6 is a network layer protocol that allows communication to take place over the network.
- IPv6 was designed with the purpose of superseding the IPv4 due to the global exponentially growing internet users.

IPv4 vs IPv6

- An IPv4 address consists of four numbers, each of which contains one to three digits, with a single dot (.) separating each number or set of digits. **25.59.209.224**
- Each of the four numbers can range from 0 to 255.
- This group of separated numbers creates the addresses that let you and everyone around the globe to send and retrieve data over our Internet connections.
- The IPv4 uses a 32-bit address scheme allowing to store 2^{32} addresses which is more than 4 billion addresses.
- To date, it is considered the primary Internet Protocol and carries 94% of Internet traffic.

- Initially, it was assumed it would never run out of addresses but the present situation paves a new way to IPv6, let's see why?
- An IPv6 address consists of eight groups of four hexadecimal digits. Here's an example IPv6 address:
`3001:0da8:75a3:0000:0000:8a2e:0370:7334`
- This new IP address version is being deployed to fulfil the need for more Internet addresses.
- It was aimed to resolve issues which are associated with IPv4.
- Comes With 128-bit address space,
- IPv6 also called IPng (Internet Protocol next generation).

Types of IPv6 Address

- Now that we know about what is IPv6 address let's take a look at its different types.
- Unicast Address: It identifies a unique node on a network and usually refers to a single sender or a single receiver.
- Multicast Address: It represents a group of IP devices and can only be used as the destination of a datagram.
- Anycast Address: It is assigned to a set of interfaces that typically belong to different nodes.

IPv4	IPv6
<u>IPv4 addresses</u> are 32 bit length.	<u>IPv6 addresses</u> are 128 bit length.
<u>IPv4 addresses</u> are <u>binary numbers</u> represented in <u>decimals</u> .	<u>IPv6 addresses</u> are <u>binary numbers</u> represented in <u>hexadecimals</u> .
<u>Checksum field</u> is available in <u>IPv4 header</u> .	No checksum field in <u>IPv6 header</u> .
<u>Options fields</u> are available in <u>IPv4 header</u> .	No option fields, but <u>IPv6 Extension headers</u> are available.
<u>(ARP)</u> is available to map <u>IPv4 addresses</u> to <u>MAC addresses</u> .	<u>(ARP)</u> is replaced with a function of <u>Neighbor Discovery Protocol (NDP)</u> .
<u>Broadcast messages</u> are available.	<u>Broadcast messages</u> are not available.
Manual configuration (Static) or DHCP (Dynamic configuration) is required to configure <u>IPv4 addresses</u> .	Auto-configuration of addresses is available.

VPN

- VPN stands for [Virtual Private Network \(VPN\)](#), that allows a user to connect to a private network over the Internet securely and privately.
- VPN creates an encrypted connection that is called VPN tunnel, and all Internet traffic and communication is passed through this secure tunnel.
- Virtual Private Network (VPN) is basically of 2 types:
 1. Remote Access VPN
 2. Site to Site VPN
 3. Cloud VPN
 4. Mobile VPN
 5. SSL VPN
 6. OpenVPN

1. Remote Access VPN

- Remote Access VPN permits a user to connect to a private network and access all its services and resources remotely.
- The connection between the user and the private network occurs through the Internet and the connection is secure and private.
- Remote Access VPN is useful for home users and business users both. An employee of a company,
- while he/she is out of station, uses a VPN to connect to his/her company's private network and remotely access files and resources on the private network.

2. Site to Site VPN

- A Site-to-Site VPN is also called as Router-to-Router VPN and is commonly used in the large companies. Companies or organizations, with branch offices in different locations, use Site-to-site VPN to connect the network of one office location to the network at another office location.
- **Intranet based VPN:** When several offices of the same company are connected using Site-to-Site VPN type, it is called as Intranet based VPN.
- **Extranet based VPN:** When companies use Site-to-site VPN type to connect to the office of another company, it is called as Extranet based VPN.

3. Cloud VPN

- A Cloud VPN is a virtual private network that allows users to securely connect to a cloud-based infrastructure or service.
- It uses the internet as the primary transport medium to connect the remote users to the cloud-based resources.
- Cloud VPNs are typically offered as a service by cloud providers such as Amazon Web Services (AWS) and Microsoft Azure.

4. Mobile VPN

- Mobile VPN is a virtual private network that allows mobile users to securely connect to a private network, typically through a cellular network.
- It creates a secure and encrypted connection between the mobile device and the VPN server, protecting the data transmitted over the connection.
- Mobile VPNs can be used to access corporate resources, such as email or internal websites, while the user is away from the office.
- They can also be used to securely access public Wi-Fi networks, protecting the user's personal information from being intercepted.

5. SSL VPN

- SSL VPN (Secure Sockets Layer Virtual Private Network) is a type of VPN that uses the SSL protocol to secure the connection between the user and the VPN server.
- It allows remote users to securely access a private network by establishing an encrypted tunnel between the user's device and the VPN server.
- SSL VPNs are typically accessed through a web browser, rather than through a standalone client.

6. OpenVPN

- OpenVPN is an open-source software application that uses SSL and is highly configurable and secure.
- It creates a secure and encrypted connection between two computers by encapsulating the data packets being sent between them.
- Open VPN can be used to access internal resources such as email, file servers, or databases.
- It is supported on a wide range of operating systems and devices, and can be easily configured to work with various network configurations and security settings.

Internet Security Association & Key Management Protocol (ISAKMP)

ISAKMP/Oakley protocol

- stand for Internet Security Association and Key Management Protocol (ISAKMP)
- Definition:

The ISAKMP protocol defines procedures and formats for establishing, maintaining and deleting SA information. An ISAKMP message contains an ISAKMP header followed by one or more payloads.

- Oakley key determination protocol

ISAKMP protocol

- ISAKMP header format



1. Initiator Cookie 8 bytes
Initiate SA establishment, notification or SA deletion
2. Responder Cookie: 8 byte
Responding to above
3. Next Payload:
Type of first payload in the msg
4. Mj version: 4 bit:
5. Mi Version: minor version
6. Exchange type: 8 bit
7. Flags 8 bit:
 1. Option set for exchange
8. Message ID: 4 bytes:
Find protocol state during Phase 2 negotiations
9. Length: 4 bytes:
Total length of ISAKMP

- **ISAKMP header fields:**

- **Payload types:** ISAKMP specifies different payload types. For example, an SA payload is used to start establishment of an SA. The proposal payload contains information used during the SA establishment. The key exchange payload indicates for exchanging keys using mechanisms such as Oakley, Diffie-Hellman, RSA, etc. There are many other payload types.
- **Exchange types:** There are five exchange types defined in ISAKMP. The base exchange allows the transmission of the key and authentication material. The identity protection exchange expands the base exchange to protect the identities of the user. The authentication only exchange is used to perform mutual authentication. The aggressive exchange attempts to minimize the number of exchanges at the cost of hiding the user's identities. The information exchange is used for one-way transmission of information for SA management.

Oakley key determination protocol

- refined version of the Diffie-Hellman key exchange protocol
- Diffie-Hellman offers two desirable features:
 - Creation of secret keys as and when required
 - No requirement for any preexisting infrastructure
- Diffie-Hellman also suffers from a few problems:
 - No mechanism for authentication of the parties.
 - Vulnerability to man-in-the-middle-attack.
 - Involves a lot of mathematical processing

Oakley key determination protocol

The features of Oakley:

- It has features to defeat replay attacks.
- It implements a mechanism called as cookies to defeat congestion attacks.
- It enables the exchange of Diffie-Hellman public key values.
- It provides authentication mechanisms to thwart man-in-the-middle attacks.

How Oakley to tackle the issues with Diffie-Hellman

- **Authentication:**

Oakley supports three authentication mechanisms: digital signatures, public key encryption, and secret key encryption.

- **Dealing with congestion attacks:**

Oakley uses the concept of cookies to thwart congestion attacks.

Message Types

The Oakley protocol provides for a number of message types:

- **Message 1:** To begin with, X sends a cookie and the public Diffie-Hellman key of X for this exchange, along with some other information. X signs this block with its private key.
- **Message 2:** When Y receives message 1, it verifies the signature of X using the public key of X. When Y is satisfied that the message indeed came from X, it prepares an acknowledgement message for X, containing the cookie sent by X. Y also prepares its own cookie and Diffie-Hellman public key, and along with some other information, it signs the whole package with its private key.
- **Message 3:** Upon receipt of message 2, X verifies it using the public key of Y. When X is satisfied about it, it sends a message back to Y to inform that it has received Y's public key.

Web Security

- Web Security is very important nowadays.
- Websites are always prone to security threats/risks.
- Web Security deals with the security of data over the internet/ network or web or while it is being transferred to the internet.
- For e.g. when you are transferring data between client and server and you have to protect that data that security of data is your web security.

Secure Socket Layer (SSL)

Secure Socket Layer (SSL)

- provides security to the data that is transferred between web browser and server.
- SSL encrypts the link between a web server and a browser which ensures that all data passed between them remain

Secure Socket Layer Protocols:

- private and free from attack.
- SSL record protocol
- Handshake protocol
- Change-cipher spec protocol
- Alert protocol

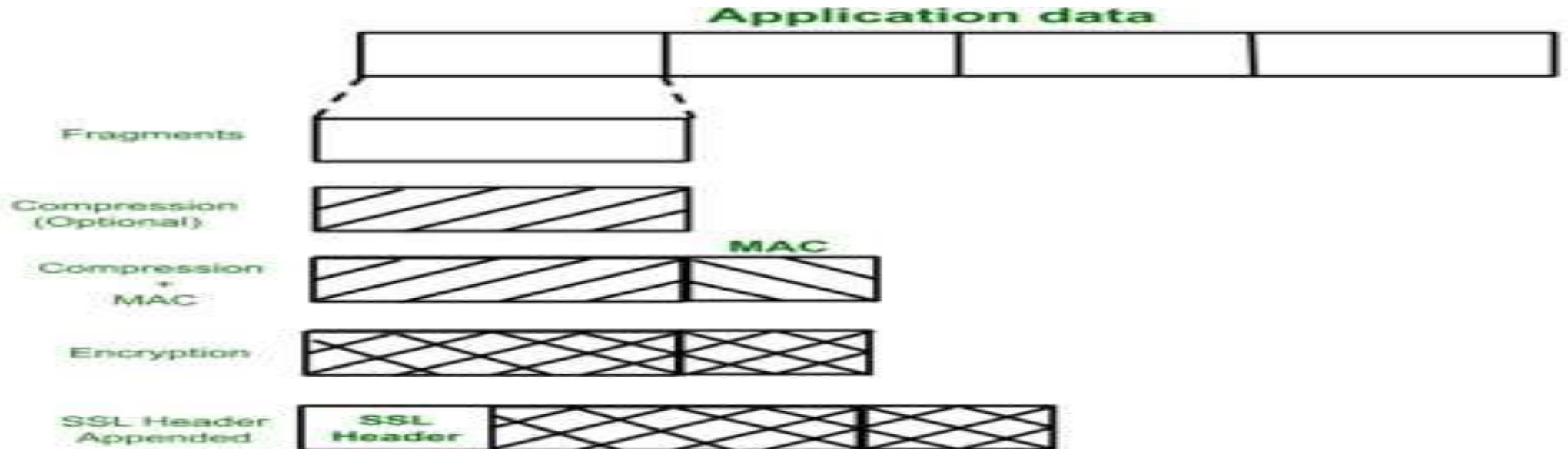
SSL Protocol Stack:

Handshake Protocol	Change Cipher Spec Protocol	Alert Protocol	HTTP
SSL Record Protocol			
TCP			
IP			

SSL Record Protocol:

- SSL Record provides two services to SSL connection.
- Confidentiality
- Message Integrity

- In the SSL Record Protocol application data is divided into fragments.
- The fragment is compressed and then encrypted MAC (Message Authentication Code) generated by algorithms like SHA and MD5 is appended.
- After that encryption of the data is done and in last SSL header is appended to the data.



Handshake Protocol:

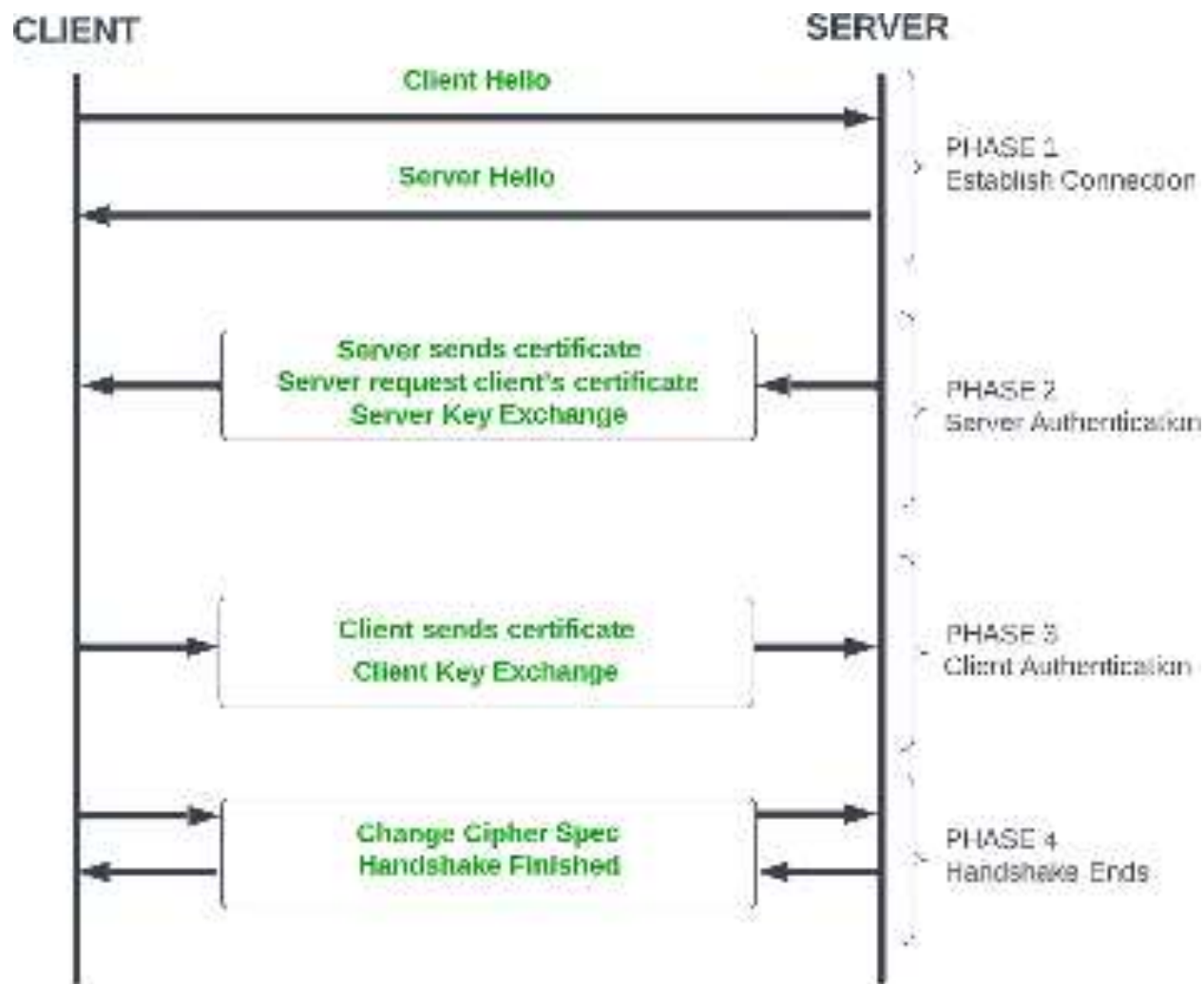
- Handshake Protocol is used to establish sessions. This protocol allows the client and server to authenticate each other by sending a series of messages to each other. Handshake protocol uses four phases to complete its cycle.

Phase 1:In Phase-1 both Client and Server send hello-packets to each other. In this IP session, cipher suite and protocol version are exchanged for security purposes.

Phase 2:Server sends his certificate and Server-key-exchange. The server ends phase-2 by sending the Server-hello-end packet.

Phase 3:In this phase, Client replies to the server by sending his certificate and Client-exchange-key.

Phase 4:In Phase-4 Change-cipher suite occurs and after this the Handshake Protocol ends.



SSL HANDSHAKE PROTOCOL

Change-cipher Protocol:

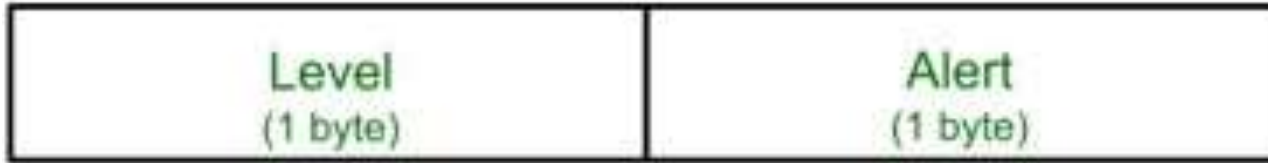
- This protocol uses the SSL record protocol. Unless Handshake Protocol is completed, the SSL record Output will be in a pending state. After the handshake protocol, the Pending state is converted into the current state.
- Change-cipher protocol consists of a single message which is 1 byte in length and can have only one value. This protocol's purpose is to cause the pending state to be copied into the current state.



1 byte

Alert Protocol:

- This protocol is used to convey SSL-related alerts to the peer entity. Each message in this protocol contains 2 bytes.



The level is further classified into two parts:

- **Warning (level = 1):**
This Alert has no impact on the connection between sender and receiver. Some of them are:
 - **Bad certificate:** When the received certificate is corrupt.
 - **No certificate:** When an appropriate certificate is not available.
 - **Certificate expired:** When a certificate has expired.
 - **Certificate unknown:** When some other unspecified issue arose in processing the certificate, rendering it unacceptable.
- **Close notify**: It notifies that the sender will no longer send any messages in the connection.
- **Unsupported certificate:** The type of certificate received is not supported.
- **Certificate revoked:** The certificate received is in revocation list.

- **Fatal Error (level = 2):**
- This Alert breaks the connection between sender and receiver. The connection will be stopped, cannot be resumed but can be restarted. Some of them are :
 - **Handshake failure:** When the sender is unable to negotiate an acceptable set of security parameters given the options available.
 - **Decompression failure:** When the decompression function receives improper input.
 - **Illegal parameters:** When a field is out of range or inconsistent with other fields.
 - **Bad record MAC:** When an incorrect MAC was received.
 - **Unexpected message:** When an inappropriate message is received.
 - The second byte in the Alert protocol describes the error.

Electronic Mail Security:

- Email (electronic mail) is a digital method by using it we exchange messages between people over the internet or other computer networks.
- With the help of this, we can send and receive text-based messages, often an attachment such as documents, images, or videos, from one person or organization to another.
- It was one of the first applications developed for the internet and has since become one of the most widely used forms of digital communication.
- It has an essential part of personal and professional communication, as well as in marketing, advertising, and customer support.

Email Security:

- Basically refers to the steps where we protect the email messages and the information that they contain from unauthorized access, and damage.
- It involves ensuring the confidentiality, integrity, and availability of email messages,
- as well as safeguarding against phishing attacks, spam, viruses, and another form of malware.
- It can be achieved through a combination of technical and non-technical measures.

PGP

- PGP is a popular program that is used to provide confidentiality and authentication services for electronic mail and file storage.
- designed in such a way, that the best cryptographic algorithms such as RSA, Diffie-Hellman key exchange, DSS are used for the public-key encryption (or) asymmetric encryption;
- CAST-128, 3DES, IDEA are used for symmetric encryption and SHA-1 is used for hashing purposes.
- PGP software is an open source one and is not dependent on either the OS (Operating System) or the processor.
- The application is based on a few commands which are easy to use.

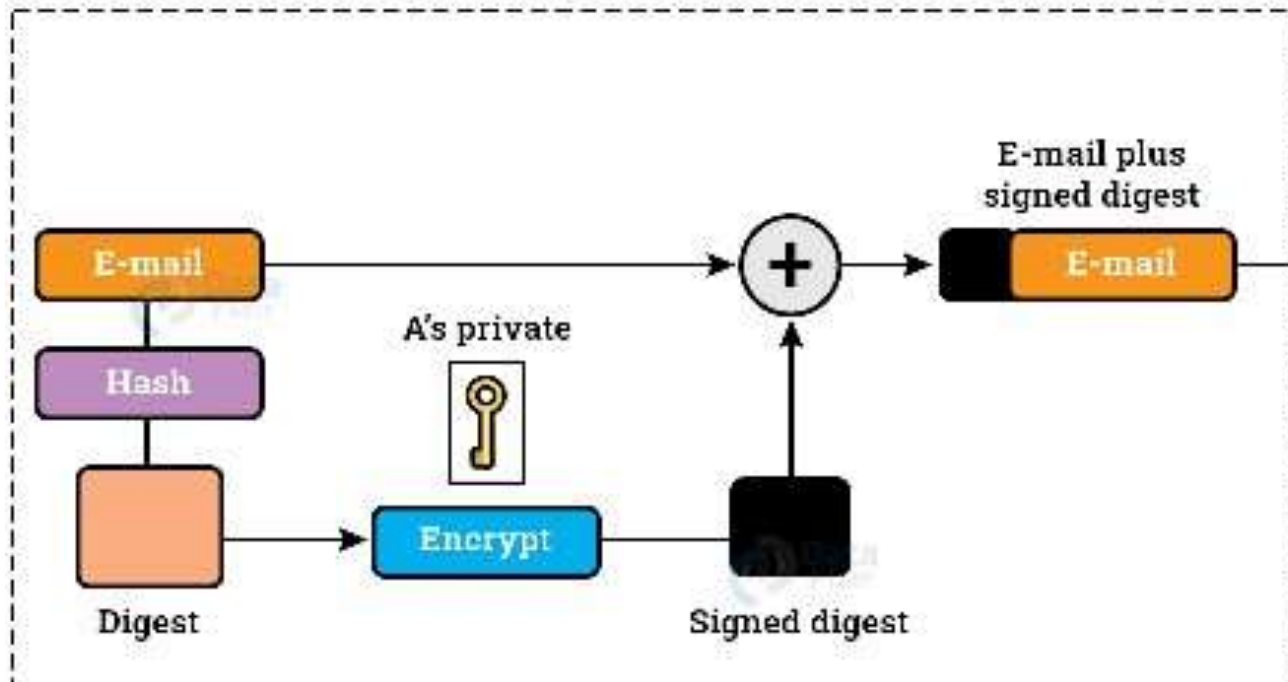
What services does PGP provide?

- PGP employs public key cryptography, symmetric key cryptography, hashing, and digital signatures. It offers:
 - Message Integrity
 - Privacy
 - Non-repudiation

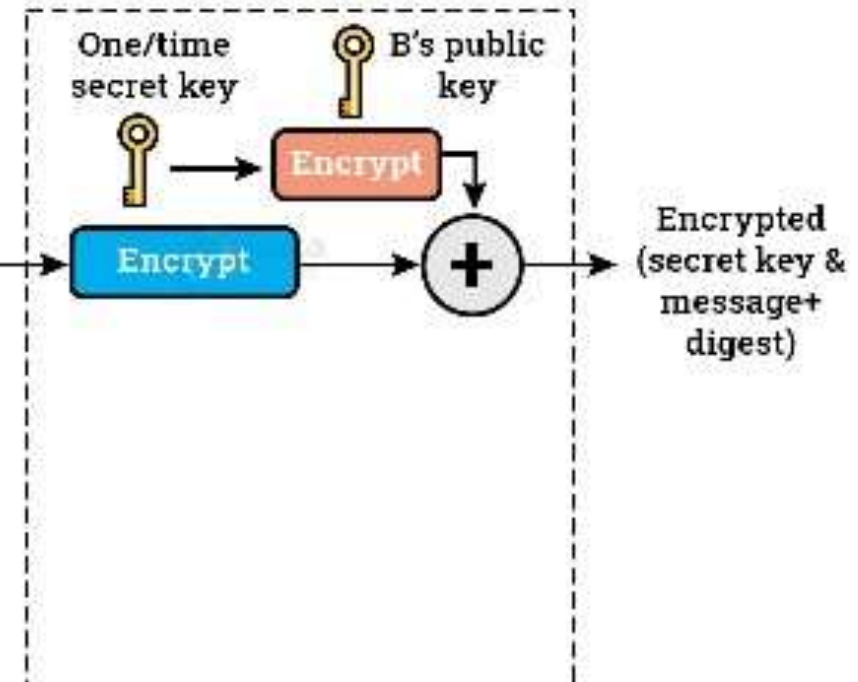
What are the steps involved in PGP?

- 1. PGP at the Sender Side:

Digital Signature

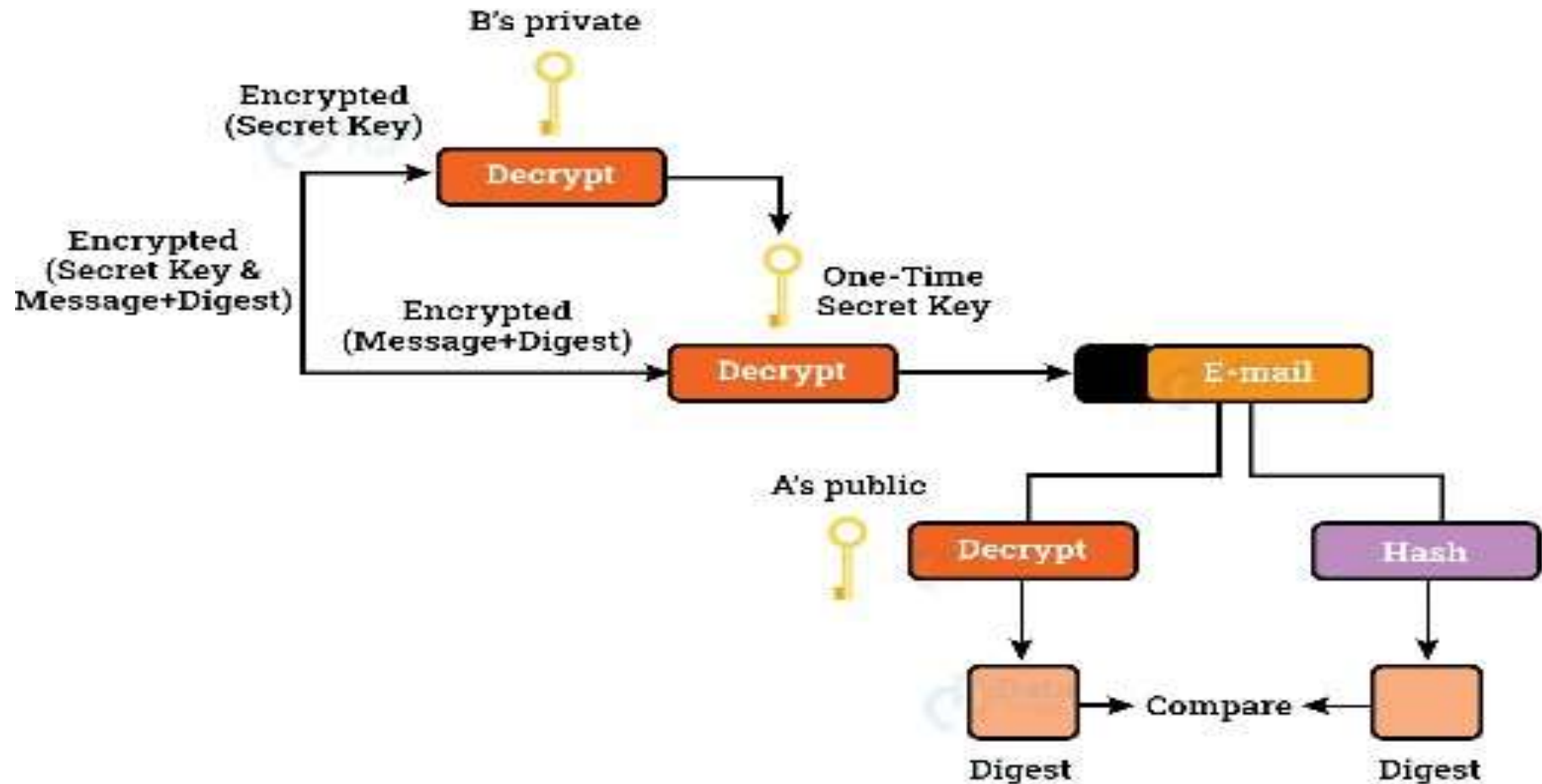


Privacy



- To generate a digest, the e-mail message is hashed using a hashing algorithm.
- The digest is then encrypted with the sender's private key to produce a signed digest, and the signed digest is appended to the original email message.
- The original message and signed digest are encrypted using the sender's one-time secret key. Public key of the recipient is used to encrypt the secret key.
- The encrypted secret key, as well as the encrypted message and digest combination, are sent simultaneously.

2. PGP at the Receiver Side:



- Both the encrypted secret key and message digest are received by the recipient.
- To get the one-time secret key, the encrypted secret key is decoded using the receiver's private key.
- The secret key is then used to decode the message and digest combination.
- The digest is decrypted using the sender's public key, and the original message is hashed to generate a digest using a hash function.
- Both digests are compared; if they are equal, it implies that all features of security are retained.

MIME Protocol – Multipurpose Internet Mail Extensions

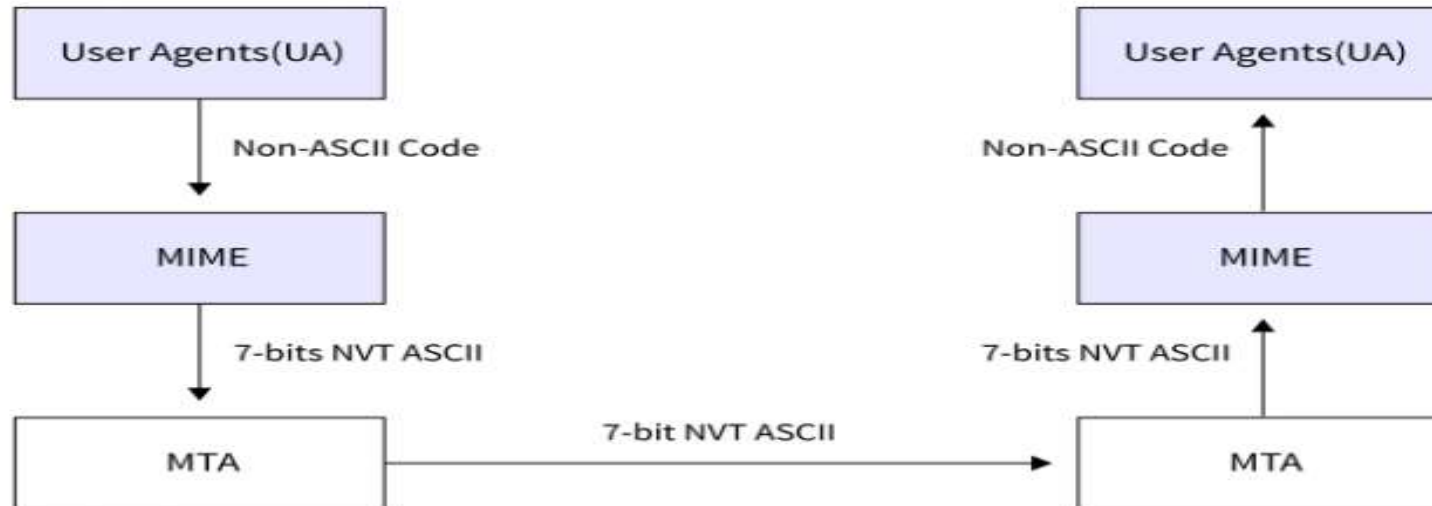
- MIME was developed in 1991 at Bell Communications by a computer scientist named Nathan Borenstein.
- MIME in computer networks stands for Multipurpose Internet Mail Extensions. MIME is an extension of its parent protocol i.e. SMTP (Simple Mail Transfer Protocol).
- It is used to enhance the capability of Internet e-mail protocols like SMTP. The MIME protocol enables users to communicate many forms of digital information via email, such as images, audio, video, and other types of documents and files.

Cont..

- MIME is an e-mail extension protocol, which means that it does not work alone, but rather collaborates with other protocols such as SMTP to enhance the capabilities of e-mail.
- MIME allows users to send emails with special elements like non-ASCII characters and send more diverse content through the email system. For example, whenever we send an email with an attachment, MIME encoding is used to package the data and transmit different parts of the email in a specific way that can be interpreted by the receiver of the mail.
- The MIME protocol is not restricted to textual data only. With the help of the MIME protocol, we can send various types of data through the internet such as: text, images, audio, video, application programs like Word document, pdf, etc.

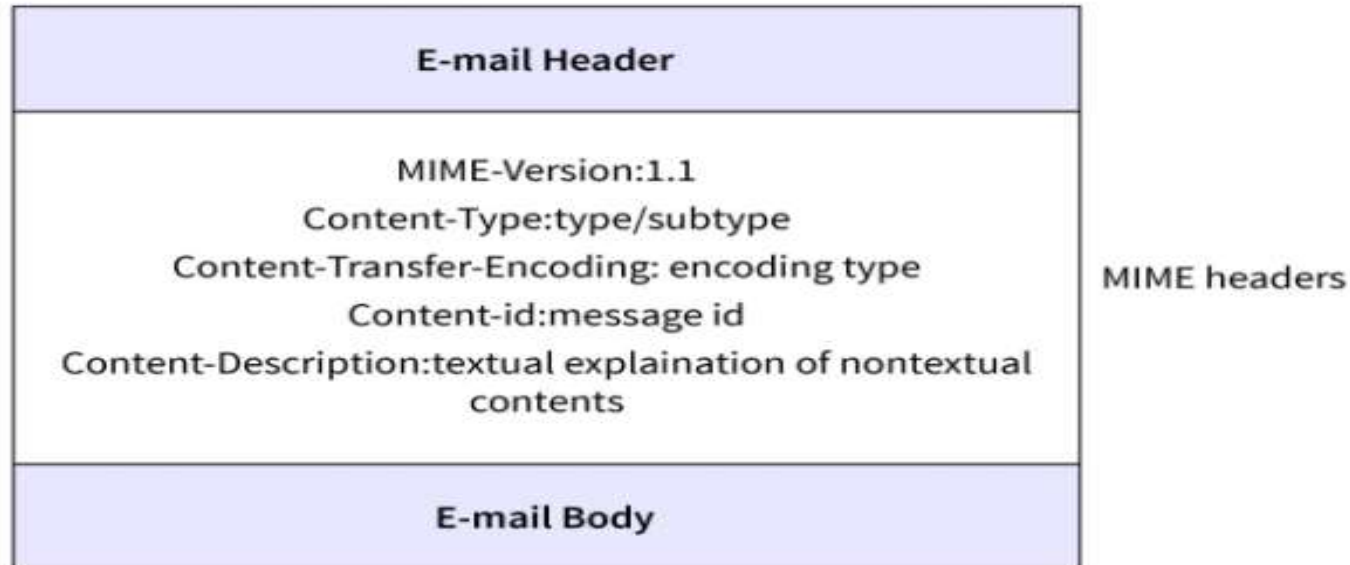
Cont..

The main usage of the MIME protocol in a computer network is to describe the content types of messages. At the sender's end, the ASCII (American Standard Code for Information Interchange) and non-ASCII data are converted into a 7-bit NVT ASCII (The Network Virtual Terminal (NVT) ASCII character set) data and then delivered the data to the respective client over the internet. When the message is received at the receiver's end, the data is again transferred to its original format. So, we can visualize the MIME protocol as a set of software functions that transforms the ASCII data to the non-ASCII data and vice-versa.



MIME Header

header is a content that is added at the start of the email to define the type of transformation and other information. The MIME header can be divided into 5 types of header or subparts, i.e. MIME-Version, Content-Type, Content-Transfer-Encoding, Content-Id, and Content-Description. Let us learn about them one by one.



Cont...

MIME-Version: MIME-Version headers indicate whether a message is in MIME format. Here is the format of this header. MIME-Version: 1.1

Content-Type: This Header file in **MIME** indicates the type of content included in the email. This can include emails, text, images, audios, videos etc. Some examples of possible content types are described below in a tabular format.

Example of Content type:-

Text	Plain or HTML
Image	JPEG, GIF
Video	—
Audio	MPEG
Message	RFC822, Partial, External-Body
Multipart	Mixed, Parallel, Digest, Alternative
Application	PostScript, Octet-Stream

Cont...

Content-Type Encoding: This header field indicates the encoding method used in the protocol to convert the **binary data** into a suitable format that can be transmitted via email. One common example of encoding is the **Base64** encoding type.

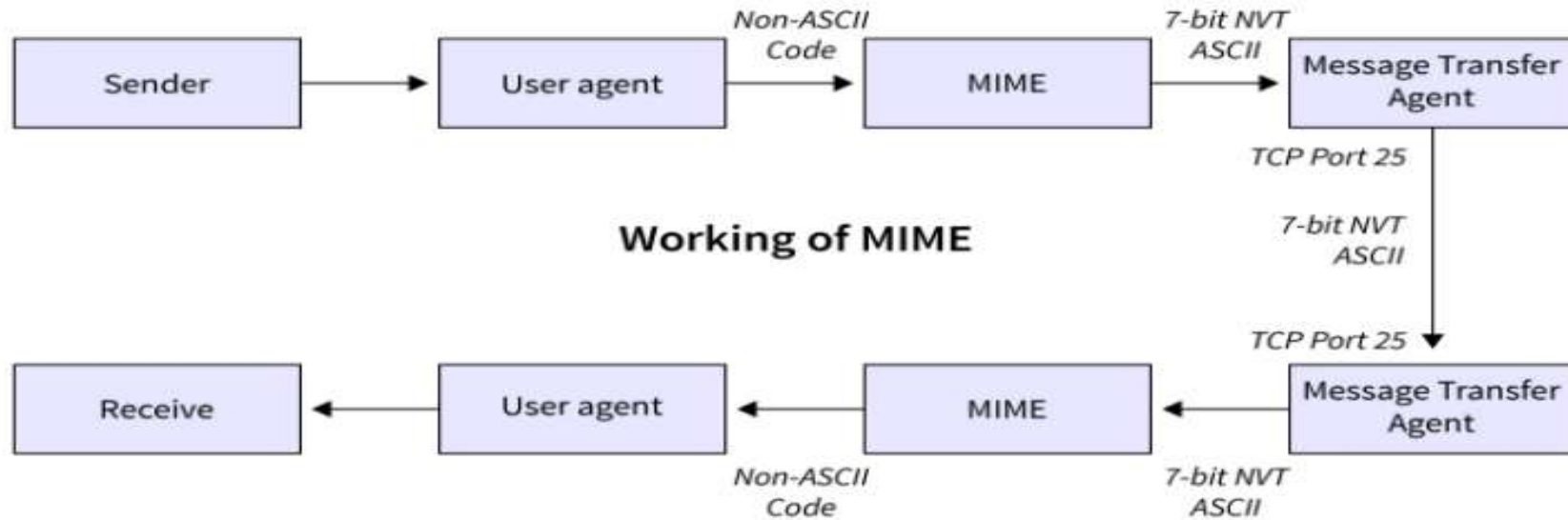
Content Id: To allow email messages to be uniquely identified, this field appends a "Content Id" number.

Content-id: id=<content-id>

Content description: The content of the email is summarized in this field. This means that whatever is sent in the mail has information about it clearly in the "Content-Description."

Content-Description:<description>

MIME Working



Cont..

MIME-formatted email can be sent via standard protocols such as **SMTP**, [POP](#), or **IMAP**. These emails may contain multiple parts. It is possible to specify the header in non-ASCII character sets supported by MIME. The MIME headers are defined in RFC 2045, which is part of the IETF.

At the beginning of email transmission, the server inserts the MIME header. A client decides which player application to use for a given data type based on the MIME header.

- Browsers and some web clients have built-in players. For example, all browsers support GIF and JPEG images and HTML files. It may be necessary to download other players like Installing Adobe Flash Player if they get an error of “No video with supported format and MIME type found” while trying to stream video on the Firefox browsers.
- MIME converts non-ASCII data into 7 bits of Network Virtual Terminal (NVT) at the sender's end. NVT represents 128 characters in 7-bit ASCII. After MIME converts this data, the data is sent to the client via SMTP. It is then transferred to the recipient's end to see the contents regardless of whether they contain text, audio, video, or another kind of data.

Advantages of MIME Protocol

- Enables transmission of non-text data over email, allowing for more versatile messages.
- Supports a variety of data types, including images, audio, and video.
- Ensures that data is properly encoded and transmitted regardless of the recipient's email client.
- Allows for the use of multiple parts in an email message, allowing for more complex messages to be sent.
- Provides a standardized way to handle email attachments.

S/MIME

- S/MIME, or Secure/Multipurpose Internet Mail Extensions, is a widely used protocol that enhances the security and privacy of email communication.
- It builds upon the MIME (Multipurpose Internet Mail Extensions) standard by adding cryptographic features to secure the content of email messages.
- S/MIME provides a framework for digital signing and encrypting email messages, ensuring that they remain confidential and tamper-proof during transmission.
- In a nutshell, S/MIME is a commonly-used protocol for sending encrypted and digitally-signed email messages and is implemented using **S/MIME certificates**.

Why Do You Need a S/MIME Email Certificate?

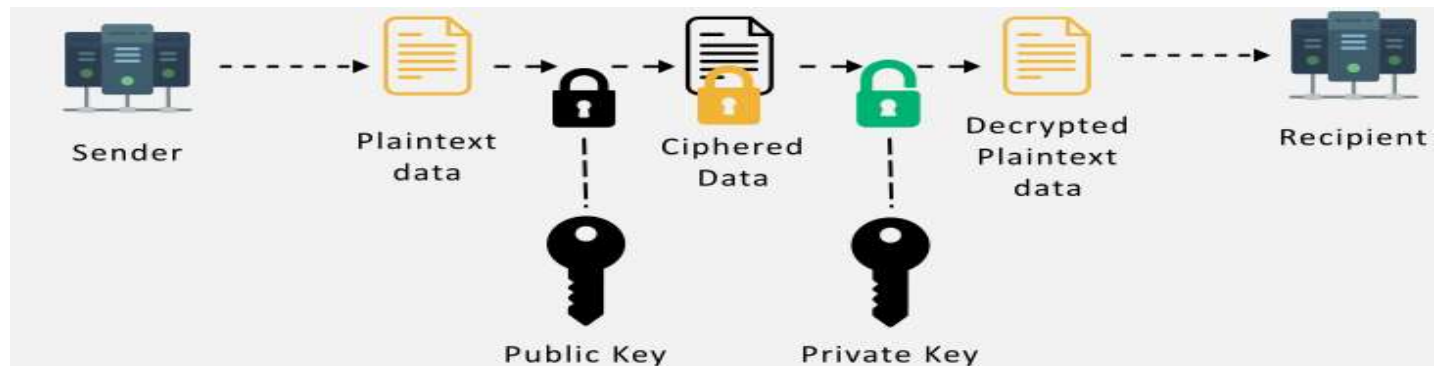
- Emails we send can be tampered with by third parties like hackers.. But this will not happen if you encrypt your email with a digital email certificate.
- This way, you can be sure that the content of the email can be accessed by only the person to whom you sent it and not by anyone else. Similarly, email certificates also secure emails that are sent.
- You might have come across server authentication SSL certificates that some email servers use. Though these certificates secure emails you receive from the secured server, they will not secure emails you send to a different email account on a different server.
- Unlike those certificates, S/MIME certificates offer end-to-end security and make sure all your email transactions are secure.

How Does a S/MIME Email Certificate Work?

- S/MIME certificates use asymmetric encryption to encrypt and secure emails.
- You can secure your email by using a S/MIME certificate. Using a public key, you can encrypt your email. Anyone, including your boss, can have this public key.
- But no one can access your email without the corresponding private key. The email you send can be decrypted only with the private key.
- Only the intended recipient, your boss, will have the private key, using which he can access the email you send.

Cont...

- You can get an email signing certificate from a certificate authority and digitally sign your emails and make them tamper-proof.
- These certificates will get attached to your email automatically soon after you make your purchase. The digital signature is associated with the public and the private keys. You will use the public key for authentication and the private key to generate the digital signature.
- This certificate will help the recipient understand that the email has not been altered or tampered with.



What Email Clients Can I Use with a S/MIME Certificate?

Microsoft Outlook

Apple Mail

Mozilla Thunderbird

Netscape Messenger

Outlook Express

Qualcomm Eudora

Cont...

- Cryptographic Algorithms Used in S/MIME In respect of the cryptographic algorithms, S/ MIME prefers the usage of the following cryptographic algorithms:
 - Digital Signature Standard (DSS) for digital signatures
 - Diffie-Hellman for encrypting the symmetric session keys
 - RSA for either digital signatures or for encrypting the symmetric session keys
 - DES-3 for symmetric key encryption

Cont...

Advantages

- It is available in various modern mail agents like Netscape, MS Outlook, etc.
- It is utilized in commercial or industrial settings.
- It ensures the message's validity and security.
- The digital signature protects the email by using email spoofing.

Disadvantages

- All users are unable to benefit from S/MIME due to the enforced certificate need because some users simply desire encryption.
- All email clients do not support S/MIME signatures.

PGP VS S/MIMS

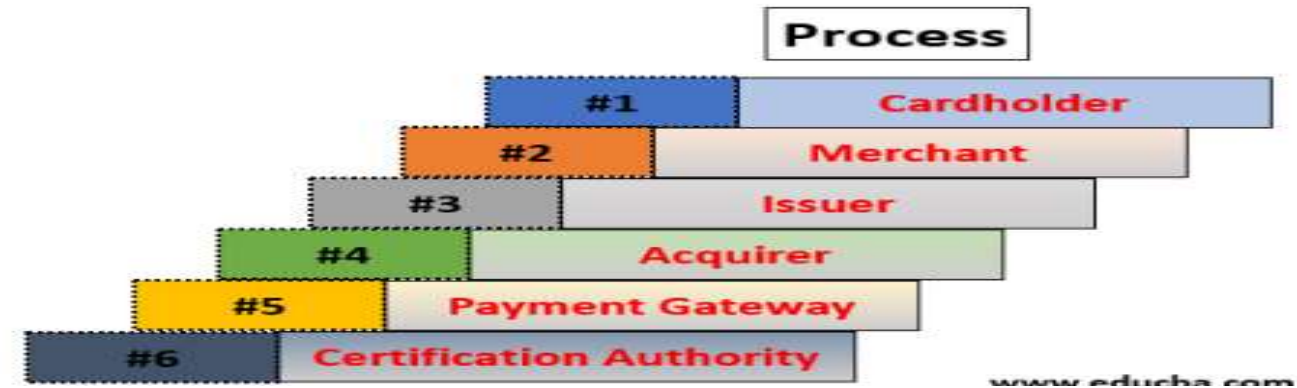
Features	PGP	S/MIME
Full form	PGP is an abbreviation for Pretty Good Privacy.	S/MIME is an abbreviation for Secure/Multipurpose Internet Mail Extension.
Effectively process	It is made to process emails in plain text.	It permits emails that also contain multimedia assets.
Cost	It is less costly than S/MIME.	It is more expensive than PGP.
Dependency	It relies on the user key exchange.	It relies on a hierarchically valid certificate for key exchange.
Usage	It is useful for both personal and organizational purposes.	It is suitable for usage in the industry.
Efficient	It is less efficient.	It is more efficient.
Convenient	It is less convenient.	It is more convenient because all applications are securely transformed.
Public Keys	It has 4096 public keys.	It has only 1024 public keys.
Encryption	It is the standard for secure encryption.	It is a robust encryption standard with some limitations.
Digital Signature	It utilizes Diffie hellman's digital signature.	It utilizes Elgamal's digital signature.
VPN	It may be utilized in VPNs.	It is utilized with email services, not VPNs.

Secure Electronic Transaction SET

- Secure Electronic Transaction (SET) was a protocol designed to secure electronic credit card transactions on the Internet.
- Developed by Visa and MasterCard, SET aimed to provide a standardized, secure way to conduct online transactions and address concerns about the security of financial information during e-commerce activities.
- Although SET was once widely discussed and considered a potential solution, it did not gain widespread adoption and has largely been replaced by other secure payment protocols.
- SET provides a secure environment for all the parties that are involved in the e-commerce transaction. It provides authentication through digital certificates.

Participants involved in the SET process:

Below is the list of participants who are involved in the SET process:



Cardholder: A cardholder is an authorized holder of the payment card. The card can be a Master card or a Visa which an issuer has issued.

Merchant: A merchant is any person or organization who wants to sell its goods and services to cardholders. Note that a merchant must have a relationship with the acquirer to accept the payment through the internet

Cont...

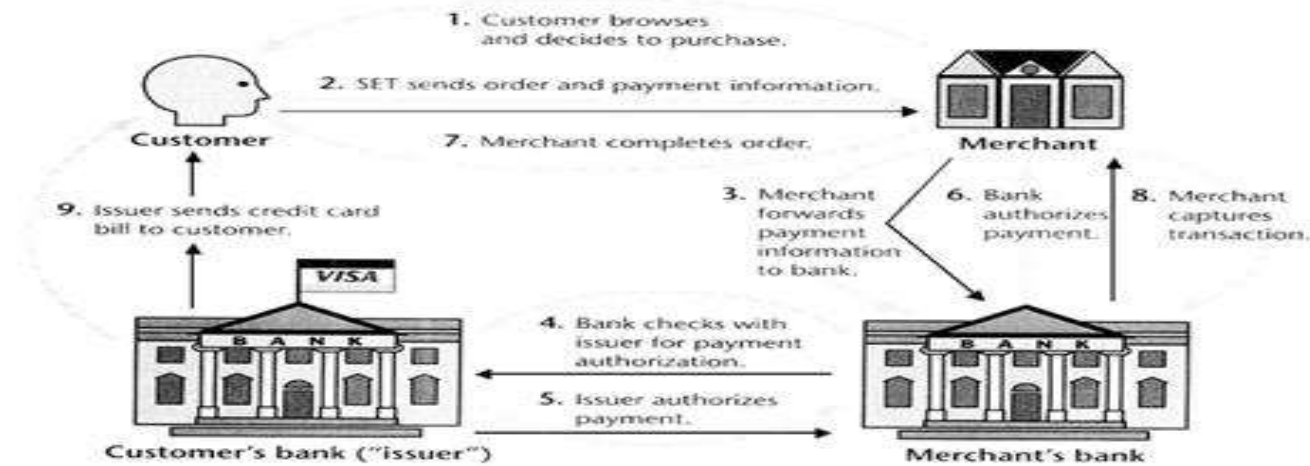
Issuer: An issuer is a financial organization such as a bank that issues payment card – Master card or visa to user or cardholder. The issuer is responsible for the cardholder's debt payment.

Acquirer: This is a financial organization with a relationship with the merchant for processing the card payment authorization and all the payments. An acquirer is part of this process because the merchant can accept credit cards of more than one brand. It also provides an electronic fund transfer to the merchant account.

Payment Gateway: For payment authorization, the payment gateway acts as an interface between secure electronic transactions and existing card payment networks. The merchant exchanges the Secure Electronic Transaction message with the payment gateway through the internet. In response to that, the payment gateway connects to the acquirer's system by using a dedicated network line.

Certification Authority: It is a trusted authority that provides public-key certificates to cardholders, payment gateways, and merchants.

General Steps



Customer to Merchant

Customer sends both the order and payment details to the merchant, together with his certificate.

The payment details will be encrypted; merchant will not be able to read the payment details.

The merchant uses the customer certificate to verify the customer.

Merchant to Customer's Bank

Merchant will send this payment details to his bank who will then forward it to the customer's bank to request authorization that the customer has sufficient available credit for the purchase.

Confirmation of Order

Once the authorization is received, the merchant will send an order confirmation to the customer.

Shipping of Goods

Upon confirmation by the customer, the merchant will deliver the goods to the customer

Request for Payment By Merchant

Lastly, the bank makes a request to the customer's credit card bank for payment.

How Secure Electronic Transaction Works?

Step 1: Customer Open an Account

The customer opens a credit card account like a master card or visa with a bank, i.e. issuer that supports electronic payment transactions and the secure electronic transaction protocol.

Step 2: Customer Receive a Certificate

Once the customer identity is verified (Verification can be done by using a passport, business documents or other documents), it receives a digital certificate which is issued by CA (Certificate Authority). This certificate contains customer details like name, public key, expiry date, certificate number, etc.

Step 3: Merchant Receives a Certificate

The merchant who wants to accept certain credit card brands must [process a digital certificate](#) for trustworthiness.

Cont...

Step 4: Customer Place an Order

It is a shopping cart process where customers borrow an item from the available list, search for the specific item according to requirements, and place the order. Once the customer places the orders, the merchant, in return, sends the details of the order, such as a list of items selected, their quantity and price, total bill, etc., to maintain a record of the order at the customer site.

Step 5: Merchant is Verified

Merchant also sends a digital certificate to the customer to ensure the customers that they are dealing with an authorized or valid merchant.

Step 6: The Order and Payment Details Are Sent

Along with the customer's digital certificate customer also sends an order and payment details to the merchant. The order part is used to confirm the transaction with the reference of items that are mentioned in the order form. The payment part contains the credit card(master card or visa) details. This payment information is in encrypted form; even the merchant cannot read it. The customer certificate ensures the merchant of a customer's identity.

Cont...

Step 7: Merchant Requests Payment Authorization

Once the merchant gets the customer's payment details, it transfers them to the payment gateway via the acquirer and requests the payment gateway to authorize the payment details. This process ensures that the customer credit card is valid, and the credit limit is not breached.

Step 8: Payment Gateway Authorizes the Payment

Using the credit card information received from the merchant, the payment gateway cross verifies the customer's credit card with the help of the issuer. Based on the verification result, it either authorizes the payment or rejects the payment.

Step 9: Merchant Confirms the Order

Assuming that the payment gateway authorizes the payment, merchants send confirmation of the order to the customer.

Step 10: Merchant Provides Goods and Services

Now the merchant provides goods and services according to the customer's order.

Step 11: Merchant Requests Payment

The merchant sends a request to the payment gateway for making payment. After that, the payment gateway interacts with various financial organizations such as the issuer, acquirer and the clearinghouse to effect the payment from the customer's account to the merchant's account.

OR.....

MIME...

SET....

MIME Protocol

- MIME stands for Multipurpose Internet Mail Extensions.
- It is used to extend the capabilities of Internet e-mail protocols such as SMTP.
- The MIME protocol allows the users to exchange various types of digital content such as pictures, audio, video, and various types of documents and files in the e-mail.

MIME Header

- MIME adds five additional fields to the header portion of the actual email to extend the properties of the simple email protocol. These fields are as follows:
- MIME Version
- Content Type
- Content Type Encoding
- Content Id
- Content description

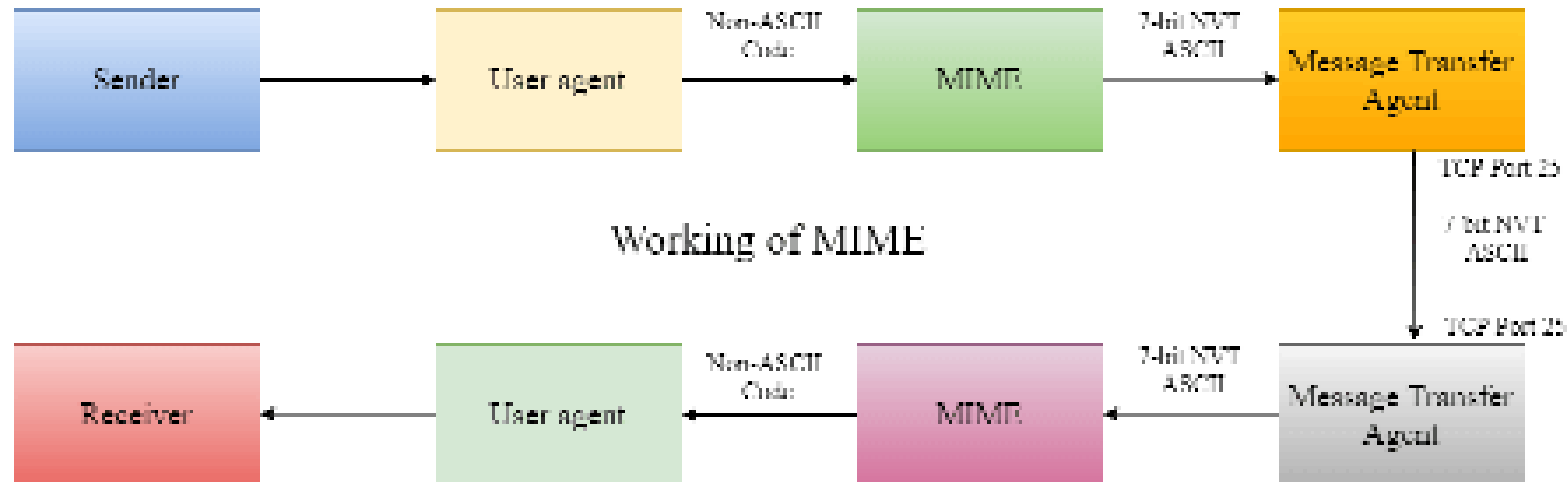
1. **MIME Version:** It defines the version of the MIME protocol.
2. **Content Type:** It describes the type of information to be sent in the message. These messages can be of many types such as Text, Image, Audio, Video, and they also have many subtypes such that image can be png or jpeg. Similarly, Video can be WEBM, MP4 etc.
3. **Content Type Encoding:**
to convert mail information into ASCII or Binary number, such as 7- bit encoding, 8-bit encoding, etc.
4. **Content Id:** In this field, a unique "Content Id" number is appended to all email messages so that they can be uniquely identified.
5. **Content description:**

This field contains a brief description of the content within the email.

Example of Content description

```
Content-Description: attachment; filename = javatpoint.jpeg;  
modification-date = "Wed, 12 Feb 1997 16:29:51 -0500";
```

Working diagram of MIME Protocol

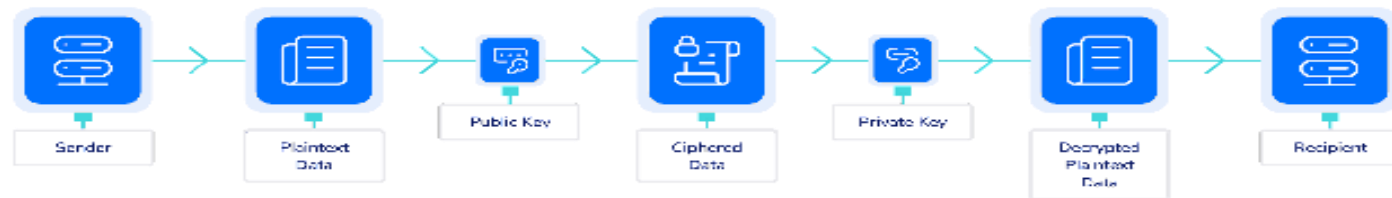


S/MIME

-

What Is S/MIME?

- S/MIME or Secure/Multipurpose Internet Mail Extension is a technology widely used by corporations that enhances email security by providing encryption, which protects the content of email messages from unwanted access. It also adds digital signatures, which confirm that you are the authentic sender of the message, making it a powerful weapon against many email-based attacks.
- In a nutshell, S/MIME is a commonly-used protocol for sending encrypted and digitally-signed email messages.



S/MIME uses

- Check that the email you sent has not been tampered with by a third party.
- Create digital signatures to use when signing emails.
- Encrypt all emails.
- Check the email client you're using.

S/MIME how it works?

- To operate, S/MIME employs mathematically related public and private keys. This technology is based on asymmetric cryptography. Because the two keys are mathematically related, a message that was encrypted with the public key (which is, of course, published) can only be decrypted using the private key (which is kept secret).
- When someone clicks “send” on an email, S/MIME sending agent software encrypts the message with the recipient’s public key, and the receiving agent decrypts it with the recipient’s private key. Needless to say, both the sender and the recipient must support S/MIME.
- The email message decryption process can only be done with the private key associated with it, which is supposed to be in sole possession of the recipient. Unless the private key is compromised, users can be confident that only the intended recipient will have access to the confidential information contained in their emails.

- Simply put, S/MIME encryption muddles emails so that they can only be viewed by receivers who have a private key to decrypt them. It prevents others, particularly malicious actors, from intercepting and reading email messages as they are sent from senders to recipients.
- You may be aware that SMTP-based Internet email does not provide message security. An SMTP (Simple Mail Transfer Protocol) internet email message can be read by anyone who sees it as it travels or views it where it is stored. S/MIME uses encryption to tackle these issues.

What is the difference between MIME and S MIME protocol?

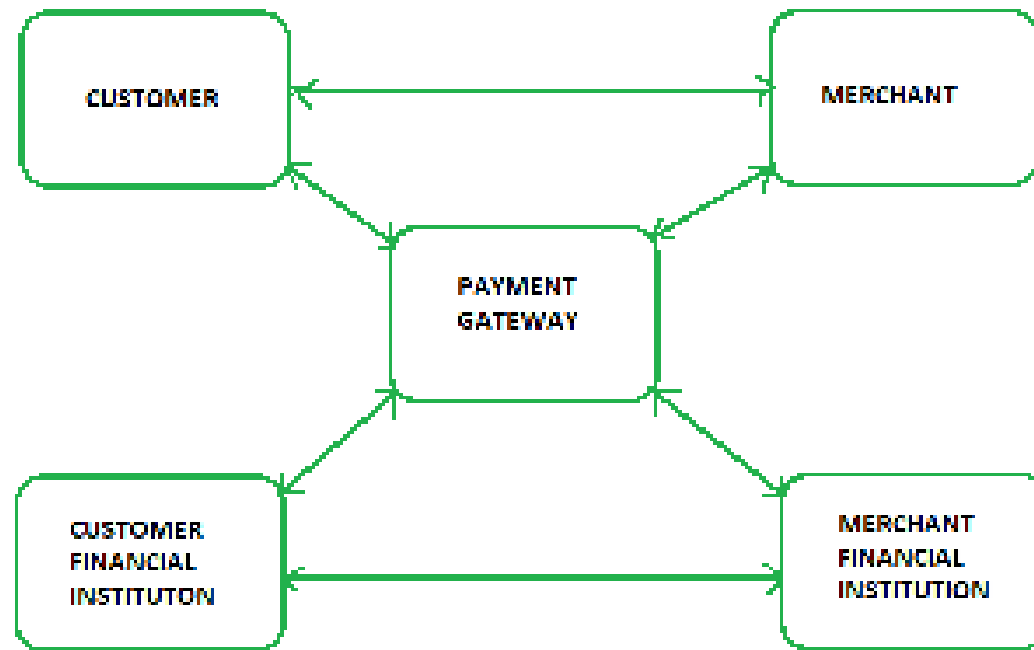
- Secure/Multipurpose Internet Mail Extension (S/MIME) : S/MIME is a security-enhanced version of Multipurpose Internet Mail Extension (MIME). In this, public key cryptography is used for digital sign, encrypt or decrypt the email.
- Purpose
- Functionality
- components
- Adoption

Secure Electronic Transaction Protocol

- Secure Electronic Transaction

SET is a system that ensures the security and integrity of electronic transactions done using credit cards in a scenario. SET is not some system that enables payment but it is a security protocol applied to those payments. It uses different encryption and hashing techniques to secure payments over the internet done through credit cards. The SET protocol was supported in development by major organizations like Visa, Mastercard, and Microsoft which provided its Secure Transaction Technology (STT), and Netscape which provided the technology of Secure Socket Layer (SSL).

- SET protocol restricts the revealing of credit card details to merchants thus keeping hackers and thieves at bay. The SET protocol includes Certification Authorities for making use of standard Digital Certificates like X.509 Certificate.
- Before discussing SET further, let's see a general scenario of electronic transactions, which includes client, payment gateway, client financial institution, merchant, and merchant financial institution.



April 2023 SPPU Question

- Q3)** a) Explore Secure Socket Layer Handshake protocol in detail. [6]
b) What is VPN? Explain types of VPN. [6]
c) Describe IPSec Protocol with its components and Security Services. [6]

OR

- Q4)** a) Distinguish between PGP and S/MIME. [6]
b) Explain ISAKMP protocol of IPSec. [6]
c) Identify Threats to web Security and figure out how any of two among listed are countered by particular feature of SSL. [6]

P.T.O.

